

RED TEAM METHODOLOGY

ANNEXES - Operational Standards, Procedures and Reference Material

Version 1.0

2026

Contents

ANNEX A — ROLES AND DECISION RIGHTS	7
A.1 Purpose	7
A.2 Appointment structure	7
A.3 Appointments	7
A.4 Separation of duties	11
A.5 Establishment	12
A.6 Responsibility by phase	13
A.7 Contact and availability	14
A.8 Independence within a chain of command	14
A.9 Relationship to the offensive function	15
ANNEX B — RULES OF ENGAGEMENT STANDARD	15
B.1 Status of the Rules of Engagement	15
B.2 Mandatory content	16
B.3 Bounded scope and exclusion	17
B.4 Conduct of operators	17
B.5 Prohibited actions	18
B.6 Social engineering	18
B.7 Capability levels	19
B.8 Change control during execution	19
B.9 Verification before signature	20
ANNEX C — ENGAGEMENT LIFECYCLE	20
C.1 The eight phases	20
C.2 Timescales	21
C.3 Alignment with recognised frameworks	21
C.4 Phase 0 — Demand and qualification	22
C.5 Phase 1 — Initiation and authorisation	23
C.6 Phase 2 — Threat intelligence	23
C.7 Phase 3 — Planning and preparation	24
C.8 Phase 4 — Execution	25
C.9 Phase 5 — Culmination and cleanup	25
C.10 Phase 6 — Reporting and debrief	26
C.11 Phase 7 — Remediation and retest	27
C.12 Compression	28
ANNEX D — PLANNING AND THREAT PROFILING	28
D.1 Principle	28
D.2 The threat profile	28
D.3 MITRE ATT&CK reference	29
D.4 The technique table	30
D.5 Objectives	31
D.6 Scenario design	32
D.7 Operational risk assessment	33
D.8 Infrastructure	34
D.9 Collection of records	35
D.10 Communications	35
ANNEX E — EXECUTION AND TRADECRAFT	35
E.1 Scope	36
E.2 Tradecraft	36
E.3 Records	37
E.4 Evidence	39
E.5 Deconfliction	40
E.6 Situation reporting	42
E.7 Attack diagram	42
E.8 Operational security	42

E.9 Hours and fatigue	43
ANNEX F — REPORTING AND METRICS	43
PART F1 — REPORTING AND DEBRIEF	43
F1.1 Function of the report	43
F1.2 Structure	43
F1.3 Detection and response	45
F1.4 Findings	45
F1.5 Severity	46
F1.6 Debriefs	46
F1.7 Distribution and handling	47
F1.8 Remediation and retest	47
F1.9 Verification before issue	48
PART F2 — MEASURES AND MATURITY	48
F2.1 Principle	48
F2.2 Measures recorded per engagement	48
F2.3 Programme measures	50
F2.4 Quarterly report	51
F2.5 Maturity	51
ANNEX G — LEGAL, SAFETY AND DATA HANDLING	52
G.1 Legal exposure and individual protection	52
G.2 Legal framework	53
G.3 The authorisation chain	55
G.4 Data protection	56
G.5 Safety	57
G.6 Discovery of a genuine intrusion	58
G.7 Personnel security	59
G.8 Professional conduct	59
G.9 Verification before authorisation	60
ANNEX H — CATEGORIES OF ENGAGEMENT	60
PART H1 — INTERNAL ASSESSMENT	60
H1.1 Characteristics	60
H1.2 The risk of the simplified authority model	61
H1.3 Variations	61
H1.4 Progression	62
H1.5 Additional cessation criteria	62
H1.6 Conduct of the internal relationship	63
PART H2 — MANDATED ENGAGEMENT	63
H2.1 The governing distinction	63
H2.2 Authority models	64
H2.3 Additional requirements at phase 1	64
H2.4 Appointments across two organisations	65
H2.5 Deconfliction between organisations	65
H2.6 Variations in execution	66
H2.7 Variations in reporting	66
H2.8 Matters raised by the assessed organisation	66
PART H3 — EXERCISE	67
H3.1 Distinction from an engagement	67
H3.2 Team structure	67
H3.3 The command element	68
H3.4 Design	68
H3.5 Pacing	69
H3.6 Injects	69

H3.7 Scoring and after-action review	69
H3.8 Internally conducted exercises	70
H3.9 Participation in external exercises	70
PART H4 — PURPLE TEAM	70
H4.1 Basis for precedence	70
H4.2 Operating models	70
H4.3 Appointments	71
H4.4 Conduct	71
H4.5 Record of results	71
H4.6 Planning	73
H4.7 Annual sequence	73
H4.8 Purple replay	73
H4.9 Limitations	74
ANNEX I — SPECIALISED ENVIRONMENTS	74
I.1 Applicability	74
I.2 Classified environments	75
I.3 Air-gapped and physically separated networks	75
I.4 Mission, command and weapon systems	76
I.5 Deployed and tactical networks	77
I.6 Installation operational technology	77
I.7 Allied and coalition systems	77
I.8 Readiness and operational tempo	78
I.9 Additional cessation criteria	78
I.10 Additional requirements at phase 1	78
ANNEX J — CAPABILITY: TOOLING, LABORATORY AND TRAINING	79
PART J1 — TOOLING AND LABORATORY	79
J1.1 Principles	79
J1.2 The laboratory	79
J1.3 Categories of tooling	80
J1.4 Selection of a command and control framework	80
J1.5 Approval of a tool	81
J1.6 Inventory	81
J1.7 Record of artefacts	81
J1.8 Custom capability	82
J1.9 Operator systems	82
J1.10 Annual review	82
PART J2 — SKILLS AND TRAINING	83
J2.1 Priority of skills	83
J2.2 Skills matrix	83
J2.3 Development	84
J2.4 Sources of training	84
J2.5 Retention of knowledge	85
J2.6 Rotation and fatigue	85
ANNEX K — BASIS, APPLICABILITY AND SOURCES	86
K.1 Applicability and hierarchy	86
K.2 Controls derived from authoritative frameworks	87
K.3 Adoption decisions	90
K.4 Commissioning questions	91
K.5 Concentration of effort	92
K.6 Controlled source register	93

ANNEX A — ROLES AND DECISION RIGHTS

Supporting Chapter 6 of the Red Team Methodology. Issued under the authority of the Head of Red Team.

A.1 Purpose

A.1.1 This annex sets out the appointments involved in an engagement, their responsibilities, the combinations of appointment that are permitted and prohibited, the establishment required, and the controls preserving independence within a chain of command.

A.1.2 Engagements fail more often through confusion of appointment than through want of technical skill. Three failures recur: authorisation given by a person not competent to give it; control of the engagement held by the element being assessed; and no appointment reachable when activity must be suspended.

A.2 Appointment structure

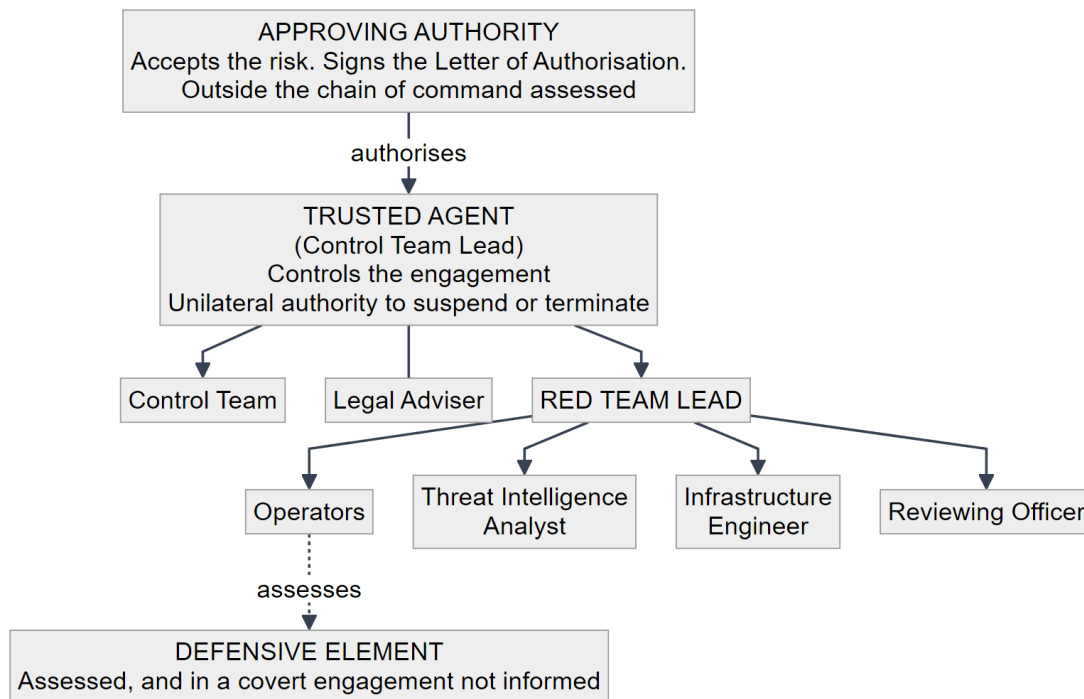


Figure A-1. Appointments in an engagement

A.3 Appointments

A.3.1 Head of Red Team

A.3.1.1 A standing appointment. Owns the capability, its personnel, its standards and the annexes to the methodology. May act as Red Team Lead on a given engagement.

Responsibilities

- Maintain the capability, its establishment, tooling and training.
- Issue and amend the annexes and pro formas, notifying the Approving Authority.
- Accept or decline requests at gate G0, recording the decision and its basis.
- Submit the quarterly report to the Approving Authority.

- e. Conduct the annual review of the methodology and the maturity assessment.

A.3.2 Approving Authority

A.3.2.1 Accepts the risk of an engagement. This appointment is frequently filled at too junior a level. It is correctly filled where the holder would have held authority, in advance, to approve a four-hour loss of a production service.

Held by	An officer holding authority to accept operational risk to the systems in scope
Shall not be	The head of the defensive element or any person whose performance or function the engagement measures
Signs	The methodology and, where operational risk authority differs from system authority, countersigns the Letter of Authorisation

A.3.2.2 Command authority and system authority are distinct. Authority to direct an assessment does not confer authority to consent to access. Where the two are held separately, both are required. See Annex G, paragraph G.2.4.

Responsibilities

- Confirm that the engagement serves a mission requirement.
- Accept the residual operational risk in writing.
- Sign or countersign the Letter of Authorisation, without substituting for the consent of the system authority where that authority is held elsewhere.
- Remain reachable, personally or through a named delegate, throughout the execution period.
- Ensure remediation is resourced.
- Adjudicate disputes between the Red Team Lead and the Trusted Agent.

A.3.3 Trusted Agent (Control Team Lead)

A.3.3.1 Controls the engagement within the assessed organisation. Holds knowledge of activity, milestones and status that would bias the defensive element if disclosed.

Held by	A senior representative of the assessed organisation with standing to halt activity and the technical understanding to judge risk
Shall not be	A member of the red team, or a member of the defensive element being assessed
Authority	Unilateral authority to suspend or terminate the engagement at any time, without justification and without consultation

A.3.3.2 The first duty of the Trusted Agent is the prevention of irreversible harm. All other duties are subordinate to it.

Responsibilities

- Maintain the authorised target space, the exclusion list and the contact list, and control changes to them.
- Monitor operational risk during execution and suspend activity where risk exceeds appetite.
- Determine whether observed activity is attributable to the red team.
- Protect the confidentiality of a covert engagement.
- Obtain the consent of system owners and third parties where required.

A.3.4 Control Team

A.3.4.1 Personnel supporting the Trusted Agent on larger engagements. On a small engagement the Trusted Agent may constitute the whole Control Team. The historical term for this function is recorded in the methodology's Lexicon and is not used as an appointment.

Responsibilities

- a. Staff the deconfliction line during agreed hours.
- b. Verify red team claims against telemetry held by the assessed organisation.
- c. Record Control Team decisions with times.
- d. Prepare the record of defensive observations used at the debrief.

A.3.5 Red Team Lead

A.3.5.1 Responsible for the conduct of one engagement, its safety, and the accuracy of its report.

Responsibilities

- a. Convert the customer's objectives into a scenario and engagement plan that can be executed safely.
- b. Own the Rules of Engagement from draft to signature.
- c. Assign operators and control the allocation of tasks.
- d. Approve each tool and technique before its first use in the environment. See Annex E, paragraph E.2.3.
- e. Ensure operator records and evidence are complete and made at the time of the action.
- f. Escalate risk to the Trusted Agent without delay or filtering.
- g. Suspend activity on any cessation criterion at Chapter 8.
- h. Own the report.

A.3.5.2 The Red Team Lead shall refuse to commence or continue an engagement where the Rules of Engagement are unsigned, scope is ambiguous, contacts are unreachable, or a cessation criterion is unresolved. That refusal is not subject to override. The defect may be corrected and readiness reconsidered through the applicable gate.

A.3.6 Operator

A.3.6.1 Conducts reconnaissance, exploitation, movement, persistence and the capture of evidence within the environment.

Responsibilities

- a. Operate within the Rules of Engagement. Where permission is uncertain, cease and consult.
- b. Maintain the operator record at the time of the action, to the standard at Annex E.
- c. Capture evidence sufficient to demonstrate impact and no more.
- d. Consult a second operator before any irreversible, high-risk or first-use action.
- e. Report without delay any suspected loss of service, contact with a system outside scope, indication of a genuine adversary, or exposure of sensitive data beyond the requirement of proof.
- f. Record each modification to a system at the time it is made.

A.3.6.2 An operator is not the last safeguard against harm. Where an operator's judgement is the only control preventing an incident, the engagement is incorrectly designed.

A.3.7 Threat Intelligence Analyst

A.3.7.1 Establishes which adversary is emulated and on what basis. At the establishment at paragraph A.5.1 this is a dedicated post.

Responsibilities

- a. Identify the adversaries that realistically threaten the target, and record the basis.
- b. Produce the threat profile on pro forma T03.
- c. Decompose the threat into an ordered set of techniques mapped to MITRE ATT&CK.
- d. Conduct target reconnaissance within the authorised bounds.

A.3.7.2 Intelligence produced by the operators who intend to use it tends toward justification of techniques already selected. The threat profile should be written by a person who will not execute it. Where that is not practicable, it shall be reviewed by a second person and the reviewer recorded in the engagement plan.

A.3.8 Infrastructure Engineer

A.3.8.1 Builds and holds the operational infrastructure.

Responsibilities

- a. Design and deploy engagement infrastructure to the standard at Annex D, paragraph D.7.
- b. Ensure command and control traffic is encrypted and infrastructure is segmented by tier.
- c. Maintain automatic logging of infrastructure activity, independent of operator action.
- d. Maintain the infrastructure inventory and complete decommissioning at culmination.
- e. Maintain the tooling baseline and verify the integrity of tools before deployment.

A.3.9 Reviewing Officer

A.3.9.1 A qualified person who did not execute the engagement and did not author the report, appointed to review it before release. The reviewer may be a red team member not assigned to the engagement, or a suitably cleared internal or external reviewer outside the delivery cell. The same independence standard applies to threat-profile review where its author will execute the plan.

Responsibilities

- a. Verify that every claim in the report is supported by recorded evidence.
- b. Verify that no finding identifies an individual.
- c. Verify that no credential, token, key or bulk sensitive data appears in the report or its appendices.
- d. Verify that severity assessments are consistent with the model at Annex F.
- e. Verify that the cleanup register is complete and signed.

A.3.9.2 The Reviewing Officer shall not be the author of the report.

A.3.10 Legal Adviser

A.3.10.1 Consulted, not embedded. Engaged at phase 1 and on any novel legal question.

Responsibilities

- a. Confirm that the authorisation chain is valid for the target and the jurisdiction.
- b. Advise on data protection, monitoring of personnel, and social engineering constraints.
- c. Advise on third-party and hosting provider terms where scope touches them.
- d. Review the Letter of Authorisation before signature.
- e. Advise on the handling and retention of evidence.

A.3.11 Defensive element

A.3.11.1 Not a red team appointment. Its conduct during an engagement is stated here because engagements produce invalid results where the defensive element behaves abnormally.

Responsibilities

- a. Defend normally. Do not alter posture because an engagement is suspected.
- b. Follow the standard incident procedure, including escalation.
- c. Preserve evidence and telemetry.
- d. Participate in the debrief.
- e. Own and implement the detection improvements arising from findings.

A.3.11.2 In a covert engagement the defensive element is not informed. In purple team activity it is a full participant. See Annex H, part H4.

A.4 Separation of duties

A.4.1 Permitted combinations

A.4.2 At the establishment at paragraph A.5.1 most appointments are held separately. The following combinations are permitted where establishment does not allow otherwise.

Combination	Condition
Red Team Lead and Threat Intelligence Analyst	Recorded in the plan; the threat profile reviewed by a second person
Red Team Lead and Operator	Permitted on small engagements; the authority to suspend is exercised separately
Operator and Infrastructure Engineer	Permitted
Trusted Agent and Control Team	Permitted on small engagements; one person may constitute the Control Team where availability and an alternate are documented
Operator and Reviewing Officer	Only in respect of an engagement on which that operator did not serve

A.4.3 Prohibited combinations

A.4.4 The following combinations shall not be held.

Combination	Reason
Red Team Lead and Trusted Agent	The appointment creating the risk would determine whether that risk is acceptable, removing the independent authority to suspend
Any red team member and Approving Authority	Self-authorisation, indistinguishable in law from an absence of authorisation
Trusted Agent and a member of the assessed defensive element, in a covert engagement	Prior knowledge invalidates the result for that element
Author of a report and its sole Reviewing Officer	No independent verification of the claims made
Approving Authority within the chain of command assessed	Risk cannot be impartially accepted on behalf of a capability the engagement judges

A.4.5 The combinations at paragraph A.4.4 are non-waivable. Where establishment cannot support the separation, a qualified external person shall fill the conflicting appointment, or the activity shall be re-scoped as an open or purple exercise. It shall not proceed as a covert red team engagement. Limited establishment does not itself constitute a compensating control.

A.5 Establishment

A.5.1 Minimum viable establishment

A.5.1.1 A two-person delivery cell is sufficient to start with SL-4 purple activity, laboratory validation and tightly scoped open assumed-breach work. A covert live engagement requires a Red Team Lead and at least two additional operators. The latter three-person composition also reflects the internal-tester benchmark in TIBER-EU and Commission Delegated Regulation (EU) 2025/1190; it is a benchmark here, not a claim of regulatory applicability.

Delivery post	Two-person startup	Three-person live cell
1	Head of Red Team; Red Team Lead; operator	Red Team Lead; may operate where workload permits
2	Operator; infrastructure; threat research	Operator; identity and endpoint; threat research
3	Not established	Operator; network, cloud and infrastructure

A.5.1.2 At either size, the Approving Authority, system authority and Trusted Agent are separate appointments outside the delivery cell. Independent threat-profile and report review shall be supplied by a qualified person who did not prepare or execute the material reviewed. A two-person cell shall not conduct covert live activity or an activity requiring one delivery member to act alone.

A.5.2 Sustainable target establishment

A.5.2.1 Six posts permit role separation, leave and training cover, independent internal review and functional specialisation. Posts 7 to 9 are added as demand and the estate require.

	Post	Primary appointment or focus
1	Head of Red Team	Capability owner; Red Team Lead on selected engagements
2	Deputy	Red Team Lead; operator; internal reviewer when not assigned
3	Operator, identity and endpoint	Operator; detection liaison
4	Operator, network and infrastructure	Operator; Infrastructure Engineer
5	Threat Intelligence Analyst	Threat profile; scenario assurance; report support
6	Infrastructure and tooling engineer	Infrastructure Engineer; operator; laboratory owner
7	Operator, cloud and identity provider	Cloud control plane and federated identity
8	Detection engineering liaison	Converts observations into validated defensive improvements
9	Operator, applications or mission systems	Selected according to the target estate

A.5.2.2 The Approving Authority, system authority, Trusted Agent, supporting Control Team and Legal Adviser are appointments held outside the delivery establishment.

A.5.3 Functional grouping

A.5.3.1 At six or more delivery personnel, functional specialisation may be more efficient than generalist parallel working. Below six, the coordination overhead exceeds the benefit and the establishment is not divided.

A.5.3.2 At the establishment described, functional focus areas are used for routine engagements. Named sub-teams are formed only for large engagements and exercises.

Sub-team	Focus
User-end device	Workstations, endpoints, phishing, user-facing initial access
Application and identity	Web, interfaces, directory, federation, cloud control plane
Network and infrastructure	Network devices, segmentation, lateral movement, engagement infrastructure
Mission systems and operational technology	Only where in scope and only under Annex I

A.5.3.3 Each sub-team has a lead. The Red Team Lead coordinates across sub-teams and is the sole point of contact with the Trusted Agent. Sub-team leads shall not communicate directly with the assessed organisation.

A.5.4 Sustainability

A.5.4.1 Two conditions govern sustainability at every establishment.

- a. No critical capability shall depend permanently on a single individual. Infrastructure build, command and control operation, report production and threat profiling shall each have a named backup. At a small establishment that backup may be a qualified person outside the delivery cell, under the same clearance, confidentiality and conflict controls. The position is recorded in the skills matrix at Annex J, paragraph J2.2.
- b. Twenty per cent of establishment time shall be reserved for development of capability.

A.5.4.2 The planning ceilings by establishment are at Chapter 10, paragraph 10.4. The team shall reduce tempo before it sacrifices independent review, cleanup, remediation support, retest, leave, training or the availability of a backup role.

A.6 Responsibility by phase

A.6.1 **A** denotes the appointment accountable, of which there is one for each activity. **R** denotes responsible; **C** consulted; **I** informed.

Phase and activity	Appr. Auth.	Trusted Agent	RT Lead	Operators
0 Accept or decline the request	A	C	R	I
1 Approve objectives and scope	A	R	C	I
1 Sign the Rules of Engagement	A	R	R	I
1 Sign the Letter of Authorisation	A	C	C	I
2 Produce the threat profile	I	C	A	C
3 Produce the engagement plan	I	C	A	R
3 Approve infrastructure	I	C	A	R
4 Execute	I	C	A	R

Phase and activity	Appr. Auth.	Trusted Agent	RT Lead	Operators
4 Deconflict an event	I	A	R	C
4 Suspend or terminate	C	A	R	I
4 Approve a change to the Rules of Engagement	A	R	R	I
5 Cleanup and verification	I	C	A	R
6 Author the report	I	C	A	R
6 Review the report	I	I	A	R
6 Deliver the debrief	I	R	A	R
7 Own remediation	A	C	C	I
7 Retest	I	C	A	R

A.6.2 The Threat Intelligence Analyst is responsible at phase 2 and consulted at phases 0, 1, 3 and 6. The Legal Adviser is responsible for the Letter of Authorisation review at phase 1 and consulted at phases 0, 1 and 4. The defensive element is consulted at phase 4 deconfliction and responsible at phases 6 and 7.

A.6.3 During execution, accountability for deconfliction and for suspension rests with the Trusted Agent and not with the Red Team Lead.

A.7 Contact and availability

A.7.1 For every engagement the Rules of Engagement shall record, for the Approving Authority, the Trusted Agent, the Red Team Lead and a named alternate for each:

- name and appointment;
- primary telephone number;
- alternate telephone number;
- email address;
- secure messaging identifier, where used;
- hours of guaranteed availability;
- out-of-hours escalation route.

A.7.2 Every number shall be verified by telephone within twenty-four hours before commencement, and the verification recorded in the engagement plan. An unverified contact list is a frequent cause of delay in acting on a requirement to cease activity.

A.8 Independence within a chain of command

A.8.1 Assessment independence and subordination are in tension. A red team subordinate to an officer whose capability it assesses will moderate its findings. This arises from the ordinary operation of hierarchy, not from dishonesty, and is not apparent to those involved.

A.8.2 The following controls are mandatory and shall be recorded in the Rules of Engagement for every engagement.

	Control	Failure prevented
1	Written right of direct report to the Approving Authority, bypassing any intermediate commander	Findings moderated in transmission
2	The Approving Authority is outside the chain of command assessed	The officer accepting the risk is also the officer judged by the result

	Control	Failure prevented
3	Reports delivered to the Approving Authority and the assessed commander simultaneously, with no prior sight and no opportunity to amend before issue	Findings negotiated before independent scrutiny
4	Severity may be disputed and the dispute recorded; it shall not be amended without record	Assessments reduced under seniority pressure
5	The Head of Red Team is not appraised by a commander whose capability the red team assesses	The reporting officer is the subject of the report
6	Refusal on legal, safety or ethical grounds is protected and escalates directly	Rank substitutes for authorisation

A.8.3 Control 3 is the control most commonly eroded, ordinarily through a request for sight of a report before issue. Such a request shall be declined. The legitimate requirements it represents are met by simultaneous delivery, by a right of written reply appended to the report, and by record of any disputed severity assessment.

A.9 Relationship to the offensive function

A.9.1 Where the organisation holds both an assurance capability and an operational effects capability, personnel may serve in or move between the two. The governing rules are at Chapter 2, paragraphs 2.10 to 2.14 of the methodology and bind every appointment in this annex.

Appointment	Requirement
Every red team member	Operates under one function at a time, under that function's authority, and records which
Red Team Lead	Refuses and reports any tasking that would employ this capability outside a signed Rules of Engagement and Letter of Authorisation, irrespective of the seniority of the originator
Approving Authority	The sole route by which capability may be transferred between the two functions
Infrastructure Engineer	Maintains separation of assurance infrastructure from operational infrastructure: no shared assets, naming or providers

ANNEX B — RULES OF ENGAGEMENT STANDARD

Supporting Chapter 5 of the Red Team Methodology. Issued under the authority of the Head of Red Team.

B.1 Status of the Rules of Engagement

B.1.1 The Rules of Engagement establish the relationship and obligations between the red team, the system owner and the assessed organisation. They govern the whole engagement and shall be observed throughout execution.

B.1.2 Three requirements are absolute.

- a. Activity shall not commence until the Rules of Engagement are signed. Verbal authority is not sufficient.
- b. An expansion or other departure from an authorised boundary requires prior written approval from every affected signing authority. Approval after the event does not retrospectively authorise it.

A restriction, suspension or stop instruction takes effect immediately and is recorded as soon as practicable.

- c. The Rules of Engagement shall be amended whenever the target space, authorised actions, objectives or scope change. A document that does not reflect current activity is not reliable evidence of the boundary being operated.

B.1.3 The Rules of Engagement and the Letter of Authorisation perform different functions. The Rules of Engagement are the operating instrument: detailed, technical, held by the team. The Letter of Authorisation is the short record of target-specific consent: signed by the system authority and countersigned by the operational risk authority where different, and carried by every operator. Neither replaces other applicable legal, contractual or provider requirements. See Annex G, paragraph G.3.

B.1.4 Pro forma T02 is used to produce them.

B.2 Mandatory content

B.2.1 Every set of Rules of Engagement shall contain the following sections. Rules of Engagement omitting any section are not valid.

	Section	Content
1	Engagement identity	Name, code name, reference, classification, version
2	Parties	Assessed organisation, red team, mandating authority where applicable
3	Purpose and objectives	The requirement; one to three objectives; the assessment objective each serves
4	Category	Service line SL-1 to SL-4; covert or open; starting posture
5	Methodology	Reference to this publication and the phase model
6	Activity types	The categories of activity permitted
7	Equipment and software	Tooling, command and control framework, infrastructure
8	Threat profile summary	Adversary emulated and capability level
9	Appointments	Each appointment and its authority
10	Deconfliction	The procedure in full, including the authentication code word
11	Cessation criteria	The list; who may invoke; the consequence
12	Communications	Channels, cadence, situation report schedule, out-of-hours arrangements
13	Data handling	What may be accessed, retained and for how long
14	Evidence and reporting	Products, recipients, classification
15	Legal and third-party authority	Applicable law, sector obligations, system-owner consent, provider policy and any third-party permission
16	Limitations	The assurance the engagement does and does not provide
17	Change control	The procedure for amendment during execution
18	Approval	Signatures of all parties, including system authority where held separately

B.2.2 The following appendices shall be attached. They are designated as appendices, not annexes, to distinguish them from the annexes to this publication.

Appendix	Content
1	Identification of the assessed organisation
2	Contact list, per paragraph A.7
3	Authorised target space
4	Excluded target space
5	Authorised actions
6	Prohibited actions
7	Objectives and success criteria
8	Threat profile, or reference to it
9	Record of changes during execution

B.3 Bounded scope and exclusion

B.3.1 Every engagement shall first define a positively authorised outer boundary: the legal entities, systems, networks, domains, cloud tenants or projects, identities, personnel groups and physical locations for which valid consent has been verified. Anything outside that boundary is outside scope. Within that boundary, an engagement may use scoping by exclusion to preserve adversary choice: targets are available only when they are inside the outer boundary and are not listed as excluded.

B.3.2 Scoping by exclusion never creates authority. It shall not be used to infer consent for a subsidiary, supplier, shared platform, cloud provider, customer, employee-owned asset or other third party. Ownership and permission are established positively before the target is included in Appendix 3.

B.3.3 Appendix 4, the excluded target space, is consequently the most safety-critical part of the document. It shall be produced by the assessed organisation and not by the red team, and shall be confirmed by the owner of each excluded system.

B.3.4 Exclusions shall cover, where applicable:

- a. systems whose unavailability creates a risk to life;
- b. systems under change freeze, migration, or known to be unstable;
- c. systems hosted by a third party that has not consented;
- d. legal, personnel, medical and privileged data stores;
- e. individuals excluded from social engineering;
- f. maintenance windows and periods of restriction;
- g. any system whose owner cannot be reached during the execution period.

B.3.5 Where ownership, permission or the status of a target is ambiguous, it is outside scope. Operators shall treat ambiguity as prohibition and seek written clarification. Only an approved amendment to the authorised outer boundary can bring it into scope.

B.4 Conduct of operators

B.4.1 The standing instructions governing operator conduct are at Chapter 8 of the methodology and are not restated here. Technique approval levels are at Annex E, paragraph E.2.3.

B.4.2 The cessation criteria are at Chapter 8, paragraph 8.15. Rules of Engagement may add criteria particular to an engagement; they shall not remove any.

B.5 Prohibited actions

B.5.1 The following are prohibited. An item marked **conditional** may be authorised only where the system authority consents, the Approving Authority records the risk acceptance, the legal adviser confirms permissibility, applicable provider or third-party conditions are met, and the Rules of Engagement state the exact limits. An item marked **absolute** shall not be authorised under this publication.

	Prohibited action	Status	Basis
1	Denial of service, resource exhaustion or availability testing	Conditional	Impact may be uncontrollable; provider policy commonly prohibits it
2	Destructive action against a live system: deletion, encryption, corruption, or ransomware emulation using genuine encryption	Absolute	Irreversible or disproportionate impact; simulate the effect instead
3	Modification of production data other than a marked, reversible artefact	Conditional	Integrity risk that may outlast the engagement
4	Exfiltration of genuine sensitive data	Absolute	Unnecessary for proof; creates legal, privacy and security exposure
5	Action against a system with a function bearing on safety of life	Absolute	Physical harm
6	Exploitation of a third-party or supplier system without that party's direct written system-owner consent	Absolute	The assessed organisation cannot confer another entity's authority
7	Physical entry, bypass of physical controls or tailgating	Conditional	Requires separate authorisation and prior arrangements for immediate verification
8	Social engineering of personal accounts, personal devices or family members	Absolute	Outside the organisation's competence to consent
9	Interception of communications not belonging to the assessed organisation	Absolute	Outside the verified authority and likely subject to additional law
10	Acquisition of credentials, access or exploits from criminal sources	Absolute	Legal and ethical exposure
11	Persistence surviving the close of the engagement	Absolute	Uncontrolled residual risk
12	Use of infrastructure that cannot be decommissioned	Absolute	Cleanup cannot be completed
13	Disclosure of engagement information outside the authorised distribution	Absolute	Confidentiality and operational security

B.6 Social engineering

B.6.1 Where social engineering is authorised under paragraph 4.8 of the methodology, the Rules of Engagement shall additionally specify:

- a. **Permitted vectors.** Email, voice, messaging, physical pretext, in person.
- b. **Permitted pretext themes, and prohibited themes.** The following are prohibited by default: redundancy or termination; pay and allowances; medical matters; bereavement; disciplinary action; security clearance; immigration status; and any theme likely to cause significant personal distress.

- c. **Target population**, defined by group and size, not by name.
- d. **Excluded individuals**, including personnel under medical or personal hardship, personnel on safety-critical duty during the period, and any individual named by the Trusted Agent.
- e. **Volume and rate limits**.
- f. **Handling of captured credentials**. Credentials shall be stored hashed or truncated, shall not be used beyond demonstrating capture unless expressly authorised, and shall be destroyed at closure.
- g. **Treatment of reporting**. A person who reports the approach has responded correctly. Results are reported as rates. Individual results shall not be reported.
- h. **Stand-down**. Where a campaign causes visible distress or disproportionate operational disruption, activity ceases and the Trusted Agent is informed.

B.7 Capability levels

B.7.1 The Rules of Engagement shall state the level of adversary capability emulated. This establishes the weight to be given to a finding and prevents the inference that any adversary could achieve the same result.

Level	Capability emulated	Characteristics
1	Opportunistic criminal	Public tooling, known exploits, indiscriminate approach, no target-specific research
2	Targeted criminal	Target-specific research, purchased access, limited evasion, financially motivated
3	State-aligned or comparably resourced	Custom tooling, patient, disciplined operational security, use of native tooling, prolonged presence
4	Insider-enabled	Any of the above, commencing with insider access or knowledge

B.7.2 A finding reachable at level 1 warrants greater urgency than the same finding reachable only at level 3, because a greater number of adversaries can reach it. The level shall be stated in both the Rules of Engagement and the report.

B.8 Change control during execution

B.8.1 Environments differ from the assumptions of the plan. Changes are expected; unrecorded changes are not.

B.8.2 The procedure is as follows.

- a. The operator or Red Team Lead identifies the requirement and holds at the boundary.
- b. The Red Team Lead submits a request to the Trusted Agent stating the change sought, the reason, the risk, and the alternative considered.
- c. The Trusted Agent approves, refuses, or refers the request to the Approving Authority.
- d. Changes that extend target space, authorise an action classified as conditional, or raise capability or risk shall be approved by the Approving Authority and every affected System Authority. Applicable legal, provider and third-party conditions shall be revalidated. An absolute prohibition is not changeable within an engagement.
- e. Each approval, consent and external permission reference is recorded in Appendix 9 with the effective date and time and the authority of the approver.
- f. The Red Team Lead briefs all operators before the change takes effect.

B.8.3 A restriction, suspension or termination communicated verbally takes effect immediately and is recorded as soon as practicable. A change that expands scope, permission, capability or risk does not take effect until the required written approval and any amended Letter of Authorisation are in force. Approval after the activity is not approval.

B.9 Verification before signature

B.9.1 The Red Team Lead shall confirm each of the following before signature and attach the completed record to the Rules of Engagement.

	Verification
1	Every mandatory section and appendix is present and complete
2	Objectives are specific, verifiable and limited to three or fewer
3	The authorised target space is positively identified and each System Authority has confirmed ownership and consent
4	Exclusions clarify the authorised outer boundary and do not substitute for it
5	Every contact has been verified by telephone within the preceding twenty-four hours
6	The out-of-hours escalation route is defined and has been tested
7	The deconfliction procedure and code word are agreed and understood by both parties
8	Cessation criteria are stated and the maximum interval without contact is set
9	Data handling covers access, storage, retention and destruction
10	Legal review is complete and recorded
11	Direct third-party consent and current provider permission are evidenced where a source, target or dependency touches them
12	The Letter of Authorisation is signed by the System Authority and operational risk is countersigned where held separately
13	Every operator has read the Rules of Engagement and confirmed the fact in writing
14	Classification and distribution are set
15	The change control procedure and Appendix 9 are in place
16	Conditional and absolute prohibitions are distinguished; no absolute prohibition is authorised

B.9.2 Verification 13 is not a formality. An operator who has not read the Rules of Engagement cannot comply with them, and the resulting non-compliance falls to the organisation.

ANNEX C — ENGAGEMENT LIFECYCLE

Supporting Chapter 7 of the Red Team Methodology. Issued under the authority of the Head of Red Team.

C.1 The eight phases

C.1.1 Every engagement follows the phases below. Small engagements compress phases in accordance with paragraph C.12. No phase is omitted.

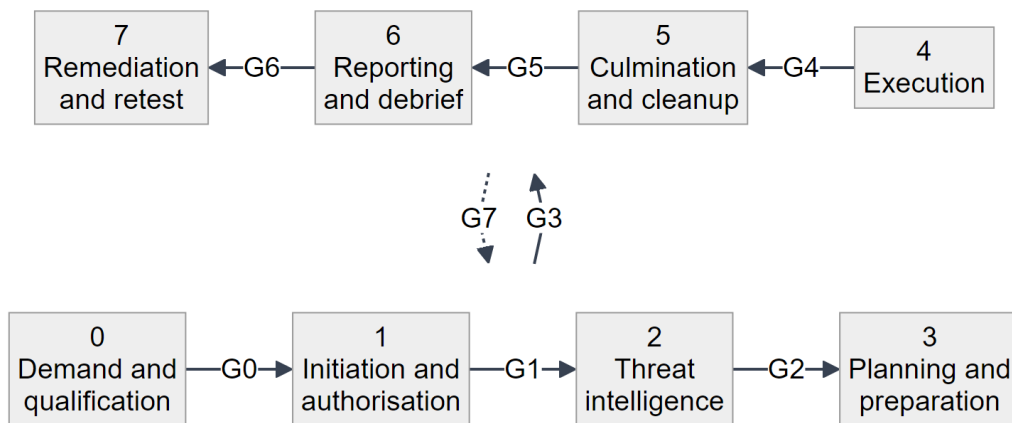


Figure C-1. Phases and gates

C.1.2 Each phase concludes at a gate. A gate is a decision by a named appointment, which either passes the engagement forward or returns it. A gate passed with criteria unmet produces an engagement that fails visibly.

C.1.3 Gate G1 is absolute. Every other gate may be passed with a recorded risk.

C.2 Timescales

C.2.1 The following are planning figures for a scoped internal engagement.

Phase	Elapsed	Effort
0 Demand and qualification	2 to 5 days	Low
1 Initiation and authorisation	5 to 10 days	Governed by signature
2 Threat intelligence	5 to 10 days	May overlap phase 1
3 Planning and preparation	5 to 10 days	High
4 Execution	10 to 20 working days	Full
5 Culmination and cleanup	2 to 3 days	Moderate
6 Reporting and debrief	5 to 10 days	High
7 Remediation and retest	30 to 90 days	Periodic
Demand to delivery of report	6 to 9 weeks	

C.2.2 Execution constitutes less than half of an engagement. A requirement expressed as a two-week engagement is a six-week engagement containing two weeks of execution.

C.2.3 Phase 6 shall not be compressed to meet a date. A report delivered late is recoverable; a report that is inaccurate is not.

C.3 Alignment with recognised frameworks

C.3.1 The phase structure follows that of the established frameworks, expanded so that each decision point has a named owner. Recorded here so that the methodology may be defended to an auditor or an assessed organisation.

Phase	TIBER-EU	NIST SP 800-115	Vest and Tubberville
0 Demand and qualification	Preparation, initiation	Planning	Engagement planning
1 Initiation and authorisation	Preparation, scoping	Planning	Engagement planning
2 Threat intelligence	Testing, threat intelligence	Discovery	Threat planning
3 Planning and preparation	Testing, red team planning	Discovery	Engagement planning
4 Execution	Testing, red team testing	Attack	Engagement execution
5 Culmination and cleanup	Closure	Attack	Engagement culmination
6 Reporting and debrief	Closure, reporting and purple teaming	Reporting	Engagement reporting
7 Remediation and retest	Closure, remediation plan	Reporting	Not addressed

C.3.2 Two departures are deliberate. Demand is separated from initiation so that declining an engagement is a recorded decision with a stated basis. Remediation and retest is constituted as a phase rather than as subsequent activity; its omission is the most common reason a programme produces no improvement.

C.3.3 Sources are at Annex K.

C.4 Phase 0 — Demand and qualification

C.4.1 **Purpose.** To determine whether the engagement should proceed and whether red teaming is the correct instrument.

C.4.2 Activities.

- Record the request on pro forma T01.
- Identify the mission or service at risk, and then the systems supporting it. The sequence is not reversed.
- Establish the decision the result will inform. Where no answer is available, the engagement does not proceed.
- Select the instrument, per paragraph 4.3 of the methodology.
- Conduct the applicability check at Annex I where the scope may include a specialised environment.
- Apply the preconditions at paragraph 4.5 of the methodology.
- Estimate effort, cost and risk. Identify candidates for Approving Authority and Trusted Agent.

C.4.3 **Gate G0**, decided by the Head of Red Team. The following shall be satisfied.

- A named mission or service is identified.
- The customer has stated the decision the result will inform.
- Red teaming is the correct instrument.
- The preconditions are met, or a lower-intensity alternative is proposed.
- A candidate Approving Authority holding sufficient authority exists.
- The legal entities and candidate System Authorities for the proposed target space are identified.
- Material providers and third parties are identified and direct permission appears obtainable.
- The establishment has capacity, separation and the necessary skills, or a plan to obtain them.

C.4.4 **Outputs.** Completed request; decision to accept or decline, with the basis recorded. A declined engagement shall be recorded with its basis and the alternative recommended.

C.5 Phase 1 — Initiation and authorisation

C.5.1 Purpose. To establish verified authority, legal review, boundaries and safety controls before any target interaction.

C.5.2 Activities.

- a. Appoint the Approving Authority and Trusted Agent in writing; identify and verify every System Authority whose consent is required.
- b. Conduct the scoping conference with the Trusted Agent, System Authorities and system owners.
- c. Define one to three objectives, each with a method of verification and a standard of evidence.
- d. Draft the Rules of Engagement on pro forma T02, with all appendices.
- e. Positively identify the authorised outer boundary and obtain consent from the competent System Authority. Obtain the exclusion list from the assessed organisation and confirmation from the owner of each excluded system.
- f. Obtain legal review of the authorisation chain, data protection, third-party terms and any social engineering constraint.
- g. Complete the applicability and provider/third-party permission registers and obtain direct consent or provider approval where required.
- h. Obtain signature on the Letter of Authorisation, pro forma T10.
- i. Verify every contact by telephone.
- j. Obtain written confirmation from each operator that the Rules of Engagement have been read.

C.5.3 Gate G1, decided by the Approving Authority. The following shall be satisfied.

1. Rules of Engagement are complete, verified against Annex B paragraph B.9, and signed.
2. The Letter of Authorisation is signed by every required System Authority and countersigned by the Approving Authority where operational risk authority differs.
3. Legal review is complete and recorded.
4. The authorised outer boundary is positively identified; third-party consent and provider permission are evidenced where required.
5. Exclusions clarify that boundary and are confirmed by the owner of each excluded system.
6. The contact list has been verified by telephone within the preceding twenty-four hours.
7. The deconfliction procedure and code word are agreed by both parties.
8. Every operator has confirmed in writing that the Rules of Engagement have been read.
9. Where Annex I applies, its phase 1 additions are satisfied.

C.5.4 Outputs. Signed Rules of Engagement; signed Letter of Authorisation; verified contact list; record of legal review.

C.5.5 Activity conducted before gate G1 is unauthorised activity.

C.6 Phase 2 — Threat intelligence

C.6.1 Purpose. To establish which adversary is emulated and on what basis.

C.6.2 Activities.

- a. Review the threat landscape: which adversaries realistically threaten the assessed organisation, given its sector, geography, mission, technology and the current situation.
- b. Select one primary adversary, and optionally one secondary. Record the basis for the selection against current reporting.
- c. Produce the threat profile on pro forma T03, to the standard at Annex D.
- d. Conduct target reconnaissance within the authorised bounds.

- e. Report any exposure representing immediate critical risk to the Trusted Agent at once. Such matters shall not be held for the report.
- f. Derive three to five attack path hypotheses from the starting posture to each objective.

C.6.3 **Gate G2**, decided by the Red Team Lead and endorsed by the Trusted Agent.

1. The adversary is named and the selection justified against current reporting.
2. The threat profile is complete and mapped to MITRE ATT&CK.
3. Reconnaissance remained within authorised bounds.
4. Critical exposures identified during reconnaissance have been reported.
5. Not fewer than three attack path hypotheses reach at least one objective.
6. Source reliability, information confidence, disagreements, limitations and the intelligence cut-off date are recorded.
7. The ATT&CK release and verification date are recorded.
8. Stable source, scenario, objective, action and flow identifiers establish the golden thread into the plan.
9. The capability level is agreed and recorded.

C.6.4 **Outputs**. Threat profile; attack surface report; attack path hypotheses.

C.7 Phase 3 — Planning and preparation

C.7.1 **Purpose**. To achieve readiness before the environment is entered.

C.7.2 **Activities**.

- a. Produce the engagement plan on pro forma T04.
- b. Build, test and verify the engagement infrastructure to the standard at Annex D paragraph D.7.
- c. Test every tool in a laboratory environment representative of the target.
- d. Establish the artefacts and network signature each technique produces.
- e. Establish the evidence repository; synchronise all systems to Coordinated Universal Time; and record the observed clock offset against the approved time source.
- f. Complete the operational risk assessment: for each technique, the credible failure modes, likelihood, impact, mitigation, method of reversal, and means of detecting harm.
- g. Test the deconfliction channel by placing a live call to the Trusted Agent.
- h. Produce the cleanup and restoration plan covering every planned modification, command and control deactivation, scope and date kill switches, credentials and secure channels, and the treatment of backups or snapshots that may later restore test artefacts.
- i. Confirm with system owners that applicable backup and restoration arrangements are available, and identify the person able to restore each in-scope critical service.
- j. Complete and recheck the provider and third-party permission register at Annex G, paragraph G.2.5.
- k. Conduct the briefing for all personnel cleared to know.
- l. Approve a specification for every reported measure, including event definitions or numerator and denominator, source, window, exclusions, censoring, validation and limitations.
- m. Define the evidence identifier convention, approved hash algorithm, original repository, working-copy area and any chain-of-custody requirement.

C.7.3 **Gate G3**, decided by the Red Team Lead.

1. The engagement plan is complete and briefed to all operators.
2. Infrastructure is built, tested, inventoried, and its decommissioning documented.
3. Every tool and technique has been tested in the laboratory.

4. The evidence repository is ready; all systems are synchronised to UTC; clock offset is within the locally approved tolerance and recorded.
5. The operational risk assessment is complete, with means of reversal recorded.
6. The deconfliction channel has been tested by live call.
7. A cleanup and restoration plan exists for every planned modification and residual mechanism, including backup or snapshot restoration.
8. All activity can be suspended within fifteen minutes of instruction.
9. System owners have confirmed backup and restoration readiness where system state may be affected.
10. Provider policies and third-party permissions have been rechecked and remain valid for the planned source, target, services, activity and dates.
11. Every reported measure has an approved specification and data-quality rule.
12. Evidence identification, provenance, hashing, original preservation and working-copy controls are ready and tested.

C.7.4 Outputs. Engagement plan; built infrastructure; risk assessment; tested communications.

C.8 Phase 4 — Execution

C.8.1 Purpose. To conduct the scenario within the Rules of Engagement and generate evidence.

C.8.2 Execution proceeds through the three stages at paragraph 7.8 of the methodology. Standing instructions are at Chapter 8. Detailed standards are at Annex E.

C.8.3 Daily routine.

Point	Activity
Commencement	Internal conference: position, intent for the day, risks
Continuous	Operator records made at the time of the action
Continuous	Evidence captured at the point of discovery
Close of day	Reconciliation of operator records against infrastructure and session records
Close of day	Update of the attack diagram
Close of day	Situation report to the Trusted Agent on pro forma T06

C.8.4 A day on which no situation report is submitted is treated as a loss of contact and engages the procedure at Annex E paragraph E.6.

C.8.5 Continuous verification. Before each significant action the operator establishes that the target is within the authorised space and outside the exclusions; that the action is authorised; that its effect is understood and reversible; and that it is recorded. A negative answer to any of these requires the operator to cease and consult.

C.8.6 Gate G4, decided jointly by the Red Team Lead and the Trusted Agent.

1. Objectives are achieved, or the agreed period has expired.
2. All activity remained within the Rules of Engagement, with any departure recorded and approved.
3. Operator records are complete and reconcile with infrastructure and session records.
4. Evidence for each claimed finding is captured and verified.
5. Every modification is recorded in the cleanup register.

C.8.7 Outputs. Operator records; evidence; situation reports; deconfliction records; attack diagram.

C.8.8 Objectives not achieved is a legitimate outcome indicating that the defence held. It is reported with the same rigour as achievement, recording which control prevented which technique.

C.9 Phase 5 — Culmination and cleanup

C.9.1 Purpose. To return the target environment and engagement infrastructure to the agreed state and secure the evidence.

C.9.2 Activities.

- a. Cease operations at the appointed time and confirm that all operators have done so.
- b. Reverse every modification recorded in the cleanup register, pro forma T12: implants, persistence, accounts, group memberships, delegations, keys, configuration, access control, uploaded files and data written to demonstrate access.
- c. Verify each item by a second person. Any item that cannot be reversed is transferred in writing to a named owner and remains open.
- d. Deactivate command and control; verify scope and date kill switches; then decommission infrastructure after preserving its records.
- e. Remove, revoke, rotate or restore test accounts, credentials, tokens, keys, certificates and secure communication channels as agreed with their owners.
- f. Identify backups, snapshots, images and recovery media that may contain test malware, tooling, persistence or modified configuration. Give their owners a written procedure and tracking reference preventing unsafe future restoration.
- g. Consolidate evidence; calculate or verify cryptographic hashes; preserve originals and source references; and apply retention, access and classification controls.
- h. Destroy captured credential material that is not required for an authorised retention purpose, and record destruction. Credentials still valid in the target are reset or rotated by their owner.
- i. Monitor for late callbacks or other residual test activity for the period stated in the plan, and route any detection immediately to the Trusted Agent.
- j. Conduct the internal review within forty-eight hours.
- k. Provide the Trusted Agent with the timestamped record of all red team activity, including source addresses, for reconciliation against defensive telemetry.

C.9.3 Gate G5, decided by the Trusted Agent.

1. Every item in the cleanup register is reversed and verified by a second person.
2. Items that could not be reversed are transferred in writing to a named owner.
3. Command and control is deactivated, kill switches are verified, and infrastructure is decommissioned after its records are preserved.
4. Test accounts, credentials, tokens, keys, certificates and secure channels are removed, revoked, reset, rotated or restored and verified.
5. Backup and snapshot owners have accepted a tracked future-restoration procedure where required.
6. The evidence repository is consolidated, cryptographically integrity-verified, classified and access-controlled.
7. Captured credential material is destroyed where required and destruction is recorded.
8. The residual-activity monitoring period is complete, or has a named owner and end date.
9. The activity record has been delivered to the Trusted Agent.
10. The internal review has been held.

C.9.4 Outputs. Signed cleanup register; activity record; consolidated evidence.

C.9.5 This phase is frequently curtailed. Forgotten persistence, live accounts and infrastructure outliving the engagement are the most consequential failures the capability can produce, and are ordinarily discovered by another party.

C.10 Phase 6 — Reporting and debrief

C.10.1 **Purpose.** To convert activity into decisions. The standard is at Annex F.

C.10.2 Activities.

- a. Reconstruct the timeline from operator, infrastructure and tool records.

- b. Reconcile against defensive telemetry with the defensive element: for each red action, what was observed, when, and what action followed. This cannot be established from the red team's records alone.
- c. Draft the attack narrative.
- d. Draft findings on pro forma T09, including controls that functioned.
- e. Finalise the attack diagram.
- f. Obtain review by an appointed Reviewing Officer who did not execute.
- g. Conduct the technical debrief with the defensive element.
- h. Deliver the command brief.
- i. Issue the report on pro forma T08.

C.10.3 **Gate G6**, decided by the Red Team Lead following review.

- 1. Every claim is supported by referenced evidence.
- 2. Reconciliation against defensive telemetry is complete.
- 3. Controls that functioned are reported alongside those that did not.
- 4. No individual is identified in a manner supporting disciplinary action.
- 5. No credential, token, key or bulk sensitive data appears in the report or its appendices.
- 6. Severity assessments are consistent with the model at Annex F.
- 7. Every finding has an owner, a recommendation and a method of retest.
- 8. The Reviewing Officer has signed.

C.10.4 **Outputs**. Report; command brief; technical debrief; findings with owners.

C.11 Phase 7 — Remediation and retest

C.11.1 **Purpose**. To establish that the organisation has improved.

C.11.2 **Activities**.

- a. Transfer findings to the organisation's risk register with owners and dates.
- b. Advise on remediation. The red team advises and does not implement; implementation of its own recommendations removes its independence.
- c. Conduct purple replay of the techniques that were not detected, with the detection engineering function, so that detections are built against the procedure used rather than against its description. See Annex H part H4.
- d. Retest critical and high findings once remediation is claimed.
- e. Record lessons on pro forma T11, for the assessed organisation and for the red team.
- f. Amend the annexes, technique library and scenario library as required.

C.11.3 **Gate G7**, decided by the Approving Authority.

- 1. All findings are recorded in the organisational risk register with owners and dates.
- 2. Critical and high findings have been retested and verified.
- 3. Detections exist for the principal techniques employed.
- 4. Lessons are recorded for both parties.
- 5. The annexes and libraries are amended.

C.11.4 **Outputs**. Retest record; detections; lessons; amendments.

C.11.5 A finding is closed by a passed retest and not by the closure of a task. Where the organisation elects not to remediate, that decision is recorded as a formal acceptance of risk signed by the Approving Authority with a review date. The finding remains open.

C.12 Compression

C.12.1 A purple team exercise or micro-engagement does not require the full sequence. The following compressions are permitted.

Phase	Full engagement	Compressed
0	Formal request and gate	Recorded decision of one paragraph
1	Full Rules of Engagement and Letter of Authorisation	Standing Rules of Engagement for purple team activity, with a scope note per exercise. The Letter of Authorisation remains required.
2	Full threat profile	Selection of three to ten techniques from an existing profile
3	Full plan and infrastructure	One-page test plan; techniques tested in the laboratory
4	10 to 20 days	1 to 3 days, conducted alongside the defensive element
5	Full cleanup register	No compression
6	Full report	Results table by technique, with detection actions
7	Full retest cycle	Detections built and validated in the same week

C.12.2 Authorisation, the cleanup register and the recording of evidence shall not be compressed.

ANNEX D — PLANNING AND THREAT PROFILING

Supporting Chapter 7, phases 2 and 3, of the Red Team Methodology. Issued under the authority of the Head of Red Team.

D.1 Principle

D.1.1 The actions of a red team are derived from a threat. They are not selected from a toolset.

D.1.2 Planning that begins from available capability produces engagements reflecting the habits of the team. The resulting findings cause the defensive element to build detections against the red team rather than against an adversary. Planning that begins from the threat produces findings that reflect actual exposure.

D.1.3 The analysis required costs a small number of days per engagement and is the practice that distinguishes red teaming from technical testing.

D.2 The threat profile

D.2.1 The threat profile is produced during phase 2 on pro forma T03 and forms Appendix 8 to the Rules of Engagement.

D.2.2 Selection of the adversary

D.2.2.1 The following questions are answered in order and the answers recorded.

	Question	Sources
1	What does the assessed organisation hold that an adversary would seek?	Mission, data, access, position in a supply chain, symbolic value

	Question	Sources
2	Which adversaries have acted against comparable organisations in the preceding 24 months?	National computer emergency response team reporting, sector information sharing, vendor reporting, published incident accounts
3	Which adversaries have acted against this organisation?	Incident history, escalations, phishing telemetry
4	What is the geopolitical and sector exposure?	Country, alliance membership, criticality, current situation
5	Which of these adversaries has publicly documented techniques capable of emulation?	ATT&CK Groups, Centre for Threat-Informed Defense emulation library, vendor reporting
6	Which is most instructive to defend against?	The adversary whose techniques overlap the widest set of plausible threats

D.2.2.2 One primary adversary is selected. A secondary may be selected where a contrasting technique set is required. More than two produces an incoherent scenario.

D.2.2.3 Where no documented group corresponds to the target, a composite profile is built from a threat category, using techniques common to several documented groups. A composite profile is legitimate and is frequently more useful than a named group with no demonstrated interest in the sector concerned. The profile shall state that it is composite.

D.2.3 Contents of the profile

Section	Content
Identity	Name, aliases, ATT&CK group identifier, or the designation “composite”
Currency	Intelligence cut-off date; profile publication date; period of activity represented
Basis	The reporting from which the profile is built, with references, source reliability, analytic confidence and material disagreement
ATT&CK reference	Enterprise ATT&CK version and the date the current matrix was verified
Motivation	Espionage, financial gain, disruption, activism, pre-positioning
Objectives against the target	What this adversary would seek from this organisation
Capability level	1 to 4 per Annex B paragraph B.7, with the basis stated
Initial access	Documented entry vectors, ranked by observed frequency
Tooling	Known tools, malware families, native binaries, custom capability
Infrastructure pattern	Hosting, domain naming, certificate practice, protocols, callback timing
Technique set	The ordered technique list to be emulated
Indicators	Indicators from reporting, used to seed detections and to distinguish emulation from the genuine actor
Techniques not emulated	Techniques excluded on grounds of safety, legality or capability, with the basis

D.2.4 The final row is mandatory. Emulation is always partial, and stating the omission prevents the report being read as assurance against the adversary as a whole.

D.3 MITRE ATT&CK reference

D.3.1 The tactic list forms the structure of every threat profile and every coverage report. The following is reproduced from the MITRE ATT&CK enterprise matrix, in the order presented there, with the stage of execution each ordinarily serves.

	Identifier	Tactic	Adversary intent	Stage
1	TA0043	Reconnaissance	Gather information to plan operations	Get In
2	TA0042	Resource Development	Establish resources to support operations	Get In
3	TA0001	Initial Access	Gain entry to the network	Get In
4	TA0002	Execution	Run malicious code	Get In
5	TA0003	Persistence	Maintain the foothold	Stay In
6	TA0004	Privilege Escalation	Obtain higher-level permissions	Stay In
7	TA0005	Stealth	Conceal activity and appear as normal behaviour	Stay In
8	TA0112	Defense Impairment	Break security mechanisms and tooling so that defenders cannot see or trust what is occurring	Stay In
9	TA0006	Credential Access	Obtain account names and passwords	Stay In
10	TA0007	Discovery	Establish the composition of the environment	Act
11	TA0008	Lateral Movement	Move through the environment	Act
12	TA0009	Collection	Gather data of interest	Act
13	TA0011	Command and Control	Communicate with compromised systems	Stay In
14	TA0010	Exfiltration	Remove data	Act
15	TA0040	Impact	Manipulate, interrupt or destroy systems and data	Act

D.3.2 At issue of this annex, ATT&CK v19 is current from 28 April 2026. It split the former Defense Evasion tactic into Stealth and Defense Impairment. ATT&CK is subject to revision; the table shall be verified against the current matrix at the commencement of every threat profile, and both version and verification date recorded. A coverage report constructed on a different matrix is not directly comparable until mappings and changes are reconciled.

D.3.3 Source: <https://attack.mitre.org/tactics/enterprise/>.

D.4 The technique table

D.4.1 The action table forms the structure of the plan, execution record and coverage report. It is constructed during phase 2 and uses stable identifiers that are retained through closure.

Action ID	Tactic and technique	Procedure	Threat source IDs	Approval level	Plan status
A-01	Initial Access — T1566.001 Spearphishing Attachment	The specific method to be used			Planned
A-02	Execution — T1204.002 User Execution				Planned
A-03	Persistence — T1053.005 Scheduled Task				Planned

D.4.2 The procedure column is the operative one. Ten teams emulating a single technique will implement it in ten ways, and defensive elements detect procedures rather than technique identifiers. Recording the exact procedure is what renders the engagement reproducible and the detection work meaningful.

D.4.3 Execution and defensive outcomes are not predicted into a single coverage field. Each action is recorded as not attempted, substituted, blocked or executed; applicable actions then record usable telemetry, alert, investigation, containment and recovery separately. See Annex F.

D.5 Objectives

D.5.1 Characteristics

D.5.1.1 A valid objective is specific, verifiable, and connected to mission impact.

Deficient objective	Deficiency	Adequate objective
Compromise the domain	Technical rather than consequential; administrative control is a step, not an effect	Demonstrate the capability to authorise a transaction above a stated value without second approval
Identify vulnerabilities	This is a penetration test	Determine whether an adversary holding a standard user account can read a stated data set within ten working days
Assess the defensive element	Not verifiable	Determine whether identity-based lateral movement is detected and escalated within the agreed period
Obtain access	No end state	Obtain and demonstrate access to the administrative interface of a stated system from an external starting posture

D.5.2 Specification

D.5.2.1 Each objective shall record:

- the end state, in one sentence;
- the mission rationale;
- the assessment objective served, per paragraph 3.3 of the methodology;
- the method of verification;
- the standard of evidence, and its limit;
- the proof that is prohibited;
- the period after which the attempt ceases.

D.5.2.2 Sub-paragraph f is what prevents an engagement becoming a data protection incident. It is settled before execution.

D.5.3 Markers

D.5.3.1 Where the objective is a location rather than a capability, a marker is placed in the target location by the Trusted Agent before execution.

D.5.3.2 Markers are preferred because retrieval demonstrates access without contact with live data, because the result is unambiguous, and because retrieval is itself an event against which the defensive element can be assessed.

D.5.3.3 A marker shall carry a unique identifier, shall contain no sensitive content, shall be recorded by the Trusted Agent with its location and the time of placement, and shall be removed at cleanup.

D.6 Scenario design

D.6.1 Components

Component	Content
Premise	The adversary, its purpose, and the point in its campaign at which the engagement commences
Starting posture	External, assumed breach, insider, or supply chain
Objectives	As specified at paragraph D.5
Phasing	The techniques allocated to Get In, Stay In and Act
Decision points	Where the plan branches according to what is found
Contingencies	The action where the primary route fails
Constraints	Period, capability level, prohibited techniques
Safety measures	Per technique

D.6.2 Starting posture

D.6.2.1 The starting posture is the most consequential planning decision.

Posture	Assesses	Selected where	Cost
External, no access	The full chain including perimeter and initial access	Perimeter and phishing resilience are genuinely in question	High; may consume the whole period without obtaining access
Assumed breach, user workstation	Everything following initial access	Detection and response are the subject of assessment	Low
Assumed breach, server or service account	Post-exploitation within the server estate	Segmentation and privileged access are the subject	Low
Insider	Controls against a malicious or compromised insider	Insider risk is a stated concern	Low
Supply chain	Trust relationships with suppliers	Third-party access is significant	Moderate; requires supplier consent

D.6.2.2 Assumed breach from a standard user workstation is the recommended default. A capable adversary will eventually obtain initial access; expending the whole period establishing that produces limited information. The defensive questions of consequence arise after access is obtained.

D.6.2.3 Where perimeter resilience requires assessment, it is conducted as a separate, time-bounded activity in parallel.

D.6.3 Attack path hypotheses

D.6.3.1 Before execution, three to five routes are recorded from the starting posture to each objective. For each: the steps, the controls expected to be encountered, and the prediction of whether each will prevent, detect or miss the activity.

D.6.3.2 The predictions constitute a finding in themselves. Where the organisation predicted that a control would detect an action and it did not, the difference between belief and effect is among the more useful outputs of an engagement. Predictions are recorded before execution and compared in the report.

D.6.4 End-to-end traceability

D.6.4.1 Every engagement maintains a golden thread from the business service at risk to the verified improvement. Stable identifiers are carried between T01 to T12 and are not replaced by titles alone.

Link	From	To	Required record
1	Critical or important service	Threat evidence	Why this threat matters to this service
2	Threat evidence	Scenario	Source references, confidence and intelligence cut-off
3	Scenario	Objective or flag	Mission effect and success criterion
4	Objective or flag	Procedure and action	Scenario ID, objective ID, procedure ID and operator-log references
5	Action	Defensive observation	Event, telemetry, alert, investigation and response references
6	Observation	Finding and remediation	Evidence references, owner, due date and expected control effect
7	Remediation	Retest and closure	Original procedure, changed control, retest result and residual risk

D.6.4.2 For a narrow engagement, the traceability table and attack-path diagram are sufficient. Where the scenario has dependencies, parallel paths or fallbacks that are hard to represent clearly, the team should also produce an Attack Flow. The current Centre for Threat-Informed Defense specification may be used for a machine-readable flow, but tooling or a formal exchange format is not a gate for a small team.

D.7 Operational risk assessment

D.7.1 An operational risk assessment is completed during phase 3 for every planned technique category, recording:

- the technique;
- the credible failure modes, including loss of service, account lockout, data corruption, alert saturation and effect on a third party;
- likelihood and impact;
- the mitigation applied before the action;
- the method of reversal;
- the means by which harm would be detected;
- the level at which approval is required.

D.7.2 A technique assessed as high impact with no method of reversal shall not be executed without written approval from the Approving Authority naming the technique and the risk accepted.

D.7.3 The following require the approval of the Trusted Agent immediately before execution, irrespective of the Rules of Engagement.

- Action against a domain controller, identity provider or certificate authority.
- Action against a hypervisor, backup system or storage platform.
- Action against operational technology, safety systems or medical devices.
- Credential attacks capable of causing account lockout at scale.
- Modification of group policy, access control or authentication configuration.
- First use of any technique in the environment.
- Any action during a change freeze, period of financial close, or major operational event.

D.8 Infrastructure

D.8.1 Tiered structure

D.8.1.1 Infrastructure is constructed in tiers so that the loss of one component does not end the engagement, and so that the components most likely to be discovered are furthest from those that must not be.

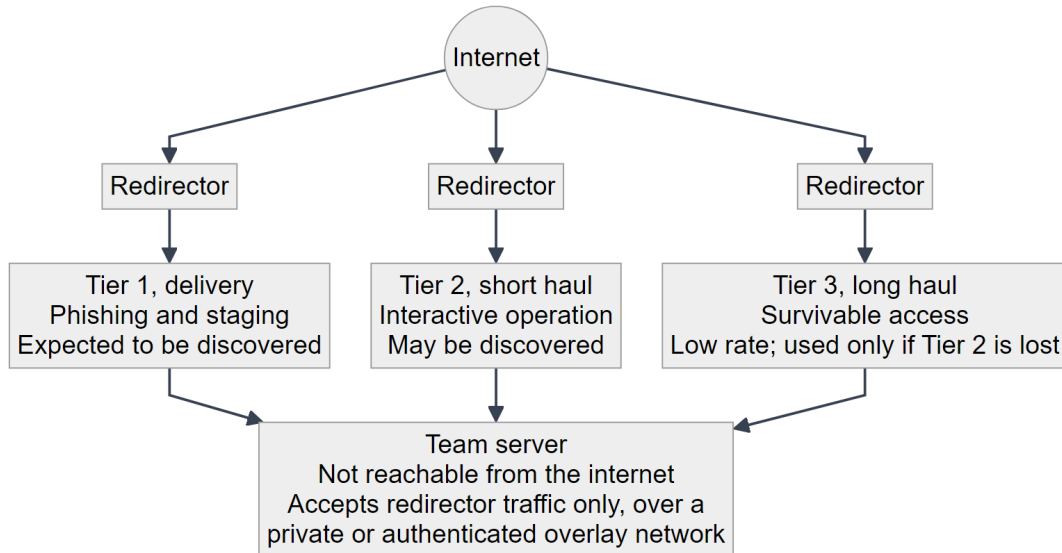


Figure D-1. Infrastructure tiers

D.8.2 Standards

D.8.2.1 The following shall be observed.

- a. All command and control traffic is encrypted.
- b. The team server is not reachable from the internet and accepts traffic only from redirectors.
- c. All infrastructure activity is logged automatically, independent of operator action.
- d. Every asset is recorded in the inventory at creation, with the appointment responsible for its decommissioning.
- e. Not fewer than two independent channels are available at each stage.
- f. The current provider and service terms permit the activity from and against the recorded accounts and resources, and any required approval for command and control, simulated events, phishing, malware testing or high-volume activity is in force. The permission register at Annex G, paragraph G.2.5, is the record.

D.8.2.2 The following shall not occur.

- a. Reuse of infrastructure or naming across engagements or across tiers.
- b. Use of infrastructure that cannot be fully decommissioned.
- c. Use of infrastructure belonging to a third party without its consent.

D.8.3 Inventory

D.8.3.1 The inventory records, for each asset: type, identifier, provider, tier, purpose, date of creation, the person who created it, method of decommissioning, date of decommissioning, and the person who verified it.

D.8.3.2 Undocumented infrastructure is the ordinary cause of live infrastructure remaining directed at an assessed organisation after an engagement has closed.

D.9 Collection of records

D.9.1 The following are settled before execution.

Matter	Standard
Location of evidence	A single encrypted repository, access controlled to the engagement team
Time standard	Coordinated Universal Time, on every system and in every record
Clock assurance	Time source, verification time, observed offset and locally approved tolerance recorded for every source system
Automatic capture	Infrastructure records, session records, tool output
Manual capture	Operator records, screenshots, rationale for decisions
Screenshot standard	Full window, including a visible time reference and host identity, redacted at the point of capture
Integrity	Cryptographic hash and algorithm recorded at collection or first consolidation; original source and repository path retained
Provenance	Collector, collection time, source system and any transfer or transformation recorded
Retention	As set in the Rules of Engagement, followed by destruction and a certificate
Classification	The highest classification of any material observed

D.9.2 Automatic session capture shall be enabled and verified on every operator system before execution. Reliance on operator recollection produces gaps at the points of greatest consequence.

D.10 Communications

D.10.1 The following channels are established.

Channel	Purpose	Parties	Frequency
Internal	Operational coordination	Red team	Continuous
Deconfliction line	Cessation, deconfliction, incident	Red Team Lead and Trusted Agent	On demand, throughout the execution period
Situation report	Status	Red Team Lead to Trusted Agent	Daily, at close of day
Steering	Progress, changes, decisions	Red Team Lead, Trusted Agent, Approving Authority	Weekly
Emergency	Suspected loss of service or genuine intrusion	Any party to the Trusted Agent	Immediate, by telephone

D.10.2 The deconfliction line shall be a telephone number answered by a person. A shared mailbox, chat channel or ticket queue is not sufficient. Where an operator believes a production system has been affected, the response time of the channel determines the consequence.

D.10.3 In a covert engagement, engagement communications shall use channels outside the monitored infrastructure of the assessed organisation. Otherwise the defensive element may discover the engagement in the course of its ordinary duties, which both invalidates the assessment and teaches the wrong lesson.

ANNEX E — EXECUTION AND TRADECRAFT

Supporting Chapters 7 and 8 of the Red Team Methodology. Issued under the authority of the Head of Red Team.

E.1 Scope

E.1.1 This annex sets the standards binding on operators during phase 4. The standing instructions governing conduct are at Chapter 8 of the methodology and are not restated here.

E.1.2 These standards produce the record required where activity is examined subsequently. The question to be answered at that point is what was done, on which date, on whose authority, and with what effect.

E.2 Tradecraft

E.2.1 Requirements

E.2.1.1 The following amplify the standing instructions at Chapter 8, paragraphs 8.8 to 8.14.

	Requirement	Basis
1	Record every significant event as it occurs: session capture, tool output, operator notes, screenshots	The record is the only durable account. Recollection is not evidence.
2	Consult a second operator before exploitation, first use of a tool, and any irreversible action	Serious incidents ordinarily arise from a single operator acting alone under time pressure
3	Establish what a tool does before it is run: its artefacts, its network signature, its failure modes	Risk that is not understood cannot be assessed, and an effect that is not understood cannot be explained
4	Assess the environment after gaining access, before acting further	Establish the function of the host, what depends on it, and what monitors it
5	Verify that the target is within the authorised space on every occasion, by address and not by name	Names change; a shared name may resolve to a system outside scope
6	Limit command and control traffic and pivot through the fewest outbound channels required	Volume is the most reliable indicator available to a defensive element
7	Prefer native and signed system tooling to introduced binaries	Lower risk, fewer artefacts, and consistent with the higher capability levels
8	Record each modification at the time it is made	Cleanup depends on it; later reconstruction is unreliable
9	Capture the screenshot at the point of discovery	The state demonstrating a finding is frequently transient

E.2.2 Prohibitions

	Prohibition	Basis
1	Introduction of untested tooling into a target environment	Untested tools cause failures, unexpected callbacks and incompatibility
2	Unencrypted command and control traffic	Trivially detected, and exposes the content of the operation
3	Exfiltration of personal, medical, financial or classified data	Demonstrate access; do not remove the data
4	Execution of binaries from atypical directories where a native alternative exists	Unnecessary artefacts and noise

	Prohibition	Basis
5	Retention of credentials, tokens or keys in notes or reports beyond the requirement of verification, and unencrypted in any case	The red team becomes the source of the compromise
6	Action against a target not verified as within scope	A frequent cause of incidents
7	Continuation past a cessation criterion	The criterion exists because the circumstance was foreseen
8	Persistence surviving culmination	Residual risk outlasting the authorisation
9	High-risk action conducted alone, outside ordinary hours, without notification of the Red Team Lead	Fatigue, isolation and privilege in combination
10	Discussion of engagement detail outside the cleared list	In a covert engagement, an overheard conversation ends the assessment

E.2.3 Approval levels

E.2.3.1 The level of approval is a property of the action in the environment concerned and not of the seniority of the operator. An experienced operator using a tool for the first time in a given environment is at the elevated level.

Level	Approval	Examples
Routine	Operator's own judgement	Passive enumeration; scanning within agreed rates; reading accessible files
Standard	Consultation with a second operator	Credential recovery from a compromised host; movement to a host within scope; standard persistence
Elevated	Red Team Lead	First use of a tool in the environment; exploitation of a service; privilege escalation; creation of accounts
High	Trusted Agent, immediately before execution	Identity infrastructure, hypervisors, backup systems, operational technology; credential attacks at scale; any change to a security control
Exceptional	Approving Authority, in writing	An action expressly classified as conditional at Annex B and authorised in the ROE; never an absolute prohibition

E.2.3.2 Approval level does not convert an unlawful act, an absolute prohibition or an act outside the authorised target space into a permitted act. If a proposed high-impact action has no credible method of reversal, the plan is changed or the objective is demonstrated by a safer substitute.

E.3 Records

E.3.1 The three layers

Layer	Source	Automatic	Purpose
Operator record	Written by the operator	No	Intent, reasoning, interpretation
Session record	Terminal or session capture	Yes, mandatory	What was entered and what was returned

Layer	Source	Automatic	Purpose
Infrastructure record	Command and control framework, tooling	Yes, mandatory	Timing, callbacks, tasking

E.3.1.1 The operator record is the primary record because it is the only one that states why an action was taken. A session record establishes that a command was executed. Only the operator can state what led to the decision, what was expected, and how the result was interpreted.

E.3.1.2 Automatic capture at layers 2 and 3 shall be configured and verified before execution commences. It exists so that the diligence of an operator under pressure is not the only safeguard.

E.3.2 Fields of the operator record

E.3.2.1 The following are recorded for every action. Pro forma T05.

	Field	Content
1	Start time, UTC	Commencement of the action
2	End time, UTC	Completion
3	Operator	Person conducting the action
4	Source address	Address from which the action originated
5	Destination address	Target address
6	Destination port	Port on the target
7	Destination system	Host name or identifier
8	Pivot address and port	Intermediate host, where used
9	Uniform resource locator	Where applicable
10	Tool	Application or utility employed
11	Command	The instruction executed
12	Description	The intent of the action and its rationale
13	Output	The result, summarised, with the full output referenced
14	Result	Success, failure, partial, or prevented by a control
15	Modification	Any change made to the system, feeding the cleanup register
16	Evidence reference	Location or identifier of the artefact
17	Comment	Interpretation, decisions, anomalies

E.3.2.2 Fields 12 and 15 are the fields most frequently omitted and the fields of greatest consequence. Field 12 converts a record into an account. Field 15 makes cleanup possible.

E.3.3 Discipline

E.3.3.1 Records are made at the time of the action. Reconstruction at the close of day is a common cause of inaccuracy in reports.

E.3.3.2 Coordinated Universal Time is used on every system, in every record and on every screenshot. Before execution, each recording system is compared with the approved time source and its offset is recorded. The tolerance is set in the engagement plan. The check is repeated after a system resumes from sleep or suspension, after a time-service anomaly, and whenever records no longer align. An offset outside tolerance is corrected where safe; the affected interval and correction are recorded rather than silently normalised.

E.3.3.3 Unsuccessful actions are recorded. They constitute evidence that a control functioned and are among the more useful outputs of an engagement.

E.3.3.4 Where activity occurred, it is recorded. An unexplained interval in the record during an incident window is indistinguishable from concealment.

E.3.3.5 Operator records are reconciled against infrastructure and session records at the close of each day. Discrepancies are resolved the same day and not at the point of reporting.

E.4 Evidence

E.4.1 Evidence shall be sufficient to establish the finding without increasing risk.

E.4.2 Collected

- a. Timestamped operator, session and tool records.
- b. Screenshots showing the full window, including a visible time reference and the identity of the host.
- c. Request and response extracts, with secrets redacted at the point of capture.
- d. Alert identifiers, task references and query references.
- e. Identifiers of affected assets.
- f. The minimum proof of access: a count of records, a schema, a file name, a marker.
- g. A written statement of the mission impact.

E.4.3 Not collected

- a. Bulk sensitive data of any kind.
- b. Personal data beyond that required to demonstrate access, and never more than a single illustrative record, redacted.
- c. Passwords, tokens, private keys or session cookies, in reports or in notes.
- d. Production records not required for proof.
- e. Anything prohibited by the Rules of Engagement.

E.4.4 Redaction

E.4.4.1 Redaction is performed at the point of capture and not at the point of reporting. Unredacted material in the repository constitutes a live risk for as long as it exists, and the report is written subsequently by a person who may not know what is sensitive.

E.4.5 Captured credentials

- a. Store hashed or truncated where the credential itself is not required.
- b. Do not place a working credential in a report, an appendix or a task record.
- c. Use only as authorised, only for the engagement, and only within the period.
- d. Destroy at culmination and record the destruction.
- e. Where a credential grants access beyond the scope of the engagement, cease and report it. It shall not be used.

E.4.6 Integrity and provenance

E.4.6.1 Routine red team material is assurance evidence. It is not described as forensic evidence or as having a formal chain of custody unless the controls in this paragraph were maintained. Material that may be required for an incident investigation, regulatory submission, disciplinary dispute or legal process is escalated immediately to the evidence owner and handled under the organisation's applicable evidence procedure.

E.4.6.2 At the first stable point of collection or consolidation, each material artefact is assigned a unique evidence identifier and the following are recorded:

- a. original system, source and path or query;
- b. collector and collection method;
- c. collection date and time in UTC, including any known clock offset;
- d. hash algorithm and value, using an organisation-approved cryptographic hash;
- e. original repository location, classification and access restrictions; and
- f. the finding, action or narrative step to which the artefact relates.

E.4.6.3 Where live capture cannot be hashed without increasing operational risk, the reason is recorded and the artefact is hashed at the first stable consolidation point. The unaltered original is preserved. Cropping, annotation, conversion, redaction and other transformations are performed on a working copy and recorded against the original evidence identifier.

E.4.6.4 Where chain of custody is required, every transfer, access, copy and disposition is recorded with the person, purpose, date and time in UTC, source, destination and integrity check. Ordinary repository audit logs may provide this record where they are protected and retained for the required period.

E.4.6.5 Evidence identifiers, hashes and repository references are reconciled before the report is issued and again before destruction. A hash does not establish that content is true; it establishes whether the collected content has changed since the hash was made.

E.5 Deconfliction

E.5.1 Purpose

E.5.1.1 Deconfliction establishes, quickly and correctly, whether observed activity originates from the red team or from a genuine adversary. It guards against two failures: expenditure of defensive effort on exercise activity, and dismissal of a genuine intrusion as exercise activity. The second is the more serious.

E.5.2 Procedure

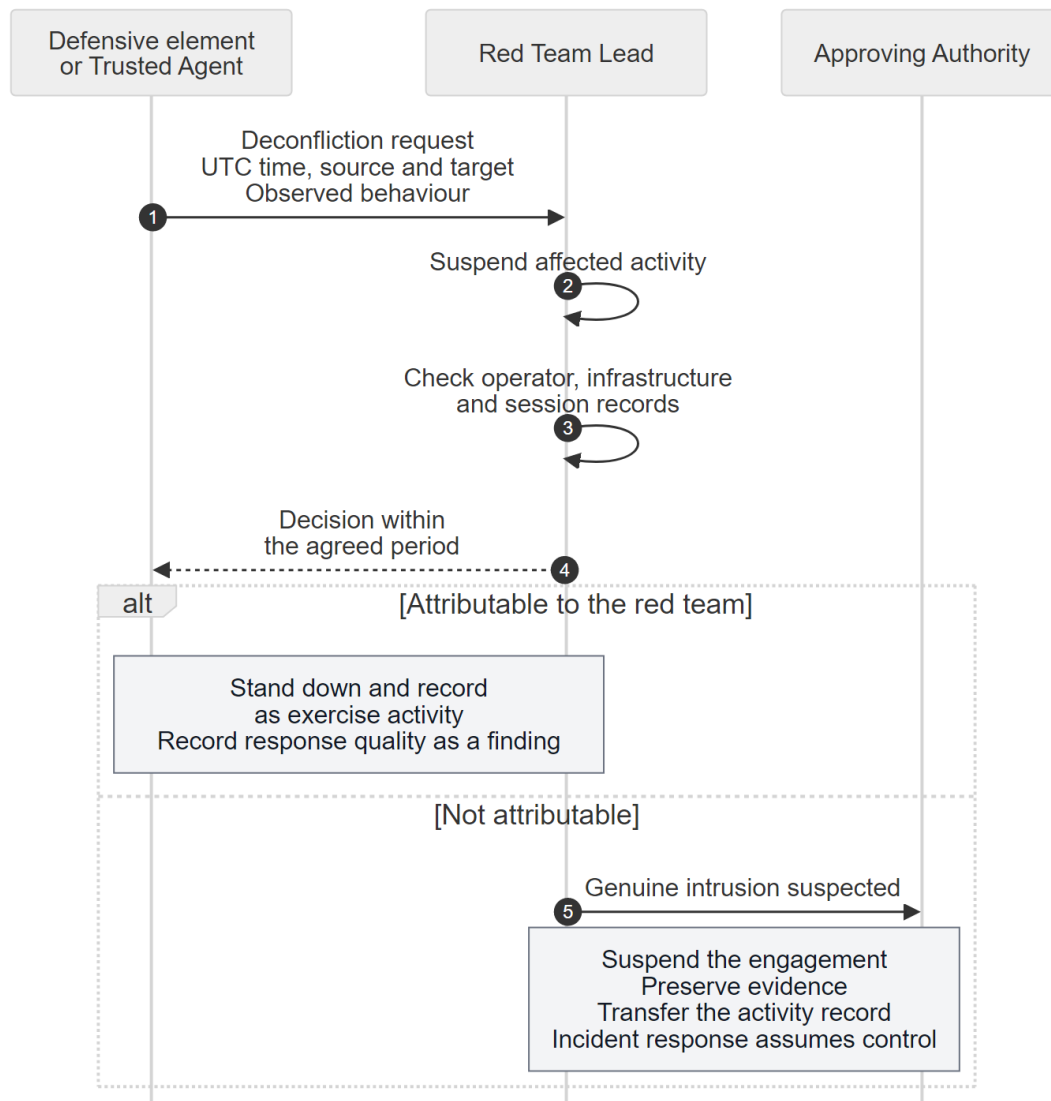


Figure E-1. Deconfliction procedure

E.5.3 Standards

E.5.3.1 A request is answered within the period set in the Rules of Engagement. The default is thirty minutes.

E.5.3.2 The determination is definitive. A determination of probable attribution is not permitted. Where the records do not establish attribution to the red team, the determination is that the activity is not attributable, and it is handled as a genuine intrusion until established otherwise.

E.5.3.3 The red team suspends activity in the affected area while the determination is made.

E.5.3.4 Every request and determination is recorded on pro forma T07, including the timeline, which becomes evidence of response times in the report.

E.5.3.5 Whether to inform the defensive element is decided by the Trusted Agent alone. In a covert engagement the element ordinarily continues to treat the activity as genuine.

E.5.4 Authentication

E.5.4.1 A code word is agreed in the Rules of Engagement and known to the Red Team Lead, the Trusted Agent and the Approving Authority. It authenticates an instruction to cease or a declaration of emergency, so that such an instruction cannot be counterfeited, including by an adversary with sight of the same correspondence.

E.5.5 Discovery of a genuine intrusion

E.5.5.1 The following sequence applies.

- a. Cease all red team activity.
 - b. Notify the Trusted Agent by telephone, using the code word.
 - c. Preserve all records and evidence in their existing state.
 - d. Transfer what is known: what was observed, when, on which host, and the full record of red team activity, so that responders can distinguish it.
 - e. Do not investigate, remediate, or interact further with the affected systems.
 - f. The engagement is suspended. Resumption requires the approval of the Approving Authority.
-

E.6 Situation reporting

E.6.1 A situation report is submitted to the Trusted Agent on every day of execution, on pro forma T06. A day on which no activity occurred is reported as such.

E.6.2 The report covers: current position; activity during the period; progress against each objective; controls encountered, whether or not they functioned; any observed defensive activity; risks and issues; deconfliction events; changes to the Rules of Engagement requested or approved; intent for the following period; and any support required from the Trusted Agent.

E.6.3 The requirement is absolute because the report is the daily confirmation that the communication channel is functioning. A day on which no report is submitted is treated as a loss of contact and engages Annex B, paragraph B.1.3 and the cessation criterion at paragraph 8.15.k of the methodology.

E.7 Attack diagram

E.7.1 An attack diagram is maintained during execution and updated not less than daily. It records the starting posture; each host, account and system accessed, with times; the route between them and the technique used for each movement; the privilege held at each stage; objectives reached; and the points at which a control prevented or detected activity.

E.7.2 Maintaining the diagram during execution rather than reconstructing it afterwards produces an accurate diagram for the report and reveals omissions in the operator record while they can still be corrected.

E.8 Operational security

E.8.1 The following apply, and apply particularly to covert engagements.

- a. Engagement communications remain outside the monitored infrastructure of the assessed organisation.
 - b. Engagement documents are not held in the file stores, task systems or mail systems of the assessed organisation.
 - c. Engagement matters are not discussed in shared accommodation, corridors, or on the messaging platform of the assessed organisation.
 - d. Operators do not access engagement infrastructure from the network of the assessed organisation.
 - e. Calendar entries carry neutral titles.
 - f. The cleared list is minimal and recorded. Each addition is recorded with the date and the authorising appointment.
-

E.8.2 Covert engagements are ordinarily compromised by a document, a calendar entry or a conversation rather than by a technical indicator.

E.9 Hours and fatigue

E.9.1 Execution outside agreed hours requires notification of the Trusted Agent.

E.9.2 High-risk actions shall not be conducted in the final hour of a long shift. Fatigue-related error on privileged systems carries the highest consequence of any error available to an operator.

E.9.3 Operators take breaks. An operator who has pursued a route for an extended period is not the appropriate person to determine whether an action is reversible.

E.9.4 The Red Team Lead is responsible for enforcing this paragraph and shall stand an operator down where judgement is degraded.

ANNEX F — REPORTING AND METRICS

Supporting Chapters 7 and 9 of the Red Team Methodology. Issued under the authority of the Head of Red Team.

Part F1 covers reporting and debriefs. Part F2 covers measures and maturity.

PART F1 — REPORTING AND DEBRIEF

F1.1 Function of the report

F1.1.1 The report is the product of the engagement. It describes a sequence of events and the response to that sequence. It is not an inventory of weaknesses.

F1.1.2 The report serves three readerships with different requirements.

Readership	Requirement	Reads
Command and the Approving Authority	The exposure, and what requires resourcing	The summary
Security leadership	Which controls failed, in what order, and what is prioritised	Summary and findings
Engineers and the defensive element	What occurred, in sufficient detail to build a detection or correct a gap	Narrative, findings, appendices

F1.1.3 All three are produced. The summary is not written for an engineer, and the narrative is not written for command.

F1.2 Structure

F1.2.1 The report is produced on pro forma T08 in the following structure.

	Section	Content
1	Document control	Classification, version, distribution, references
2	Summary	Not exceeding two pages, and comprehensible in isolation

	Section	Content
3	Method and objectives	The activity conducted; the capability level emulated; the objectives
4	Scenario and scope	Starting posture, adversary emulated, scope and exclusions, period
5	Attack narrative	The sequence of events, with critical steps and evidence
6	Detection and response	What the defensive element observed, when, and what followed
7	Technique coverage	Every technique: attempted, prevented or executed, telemetry, alert, investigation, containment and recovery
8	Findings	Each finding, including controls that functioned
9	Conclusion	Overall assessment and residual risk
10	Appendices	Timeline, activity record, indicators, evidence index, cleanup attestation

F1.2.2 The summary

F1.2.2.1 The summary states, in order:

- a. what the engagement was required to determine;
- b. what was conducted: the adversary emulated, the starting posture, the period;
- c. what occurred: the outcome against each objective;
- d. which controls functioned;
- e. which did not, in order of consequence;
- f. the three to five recommendations carrying the greatest reduction in risk;
- g. the residual risk if no action is taken.

F1.2.2.2 Sub-paragraph d is mandatory. A report omitting the controls that functioned is inaccurate and will be received as an attack upon the defensive element.

F1.2.2.3 The summary contains no technique identifiers, tool names or technical terminology.

F1.2.3 The attack narrative

F1.2.3.1 The narrative is chronological and composed of numbered critical steps. For each step:

- a. the step number and title;
- b. the date and time in UTC;
- c. the action taken, in plain language, with the technique named;
- d. the intent;
- e. the result;
- f. the evidence reference;
- g. the defensive observation.

F1.2.3.2 Sub-paragraph g is completed for every step, including where the answer is that no signal was generated, or that an alert was generated but not examined within the period. The presence of this line at every step is what distinguishes a red team report from a penetration test report.

F1.2.3.3 Only steps of consequence appear in the narrative. The complete sequence of actions appears in the appendix.

F1.3 Detection and response

F1.3.1 This section is constructed from the reconciliation with the defensive element at phase 6 and is the section that element will use. The action record and response record are kept separate so that prevention, observability and response are not collapsed into one score.

Red action ID	Time, UTC	Attempt result	Telemetry	Alert	Investigation

Red action ID	First containment	Recovery completed	Timing evidence	Assessment

F1.3.2 Coverage gaps are recorded in three categories. They carry different owners and remediation paths; a single figure for detection coverage does not permit command to act.

Category	Primary owner	Required action
No usable telemetry	Platform, identity or endpoint engineering	Establish or repair the source and validate data quality
Telemetry present, no effective detection	Detection engineering	Design and validate detection against replay
Alert generated, not examined in the required window	Defensive operations management	Correct priority, routing, capacity or procedure and re-exercise

F1.3.3 The attack path hypotheses recorded at Annex D, paragraph D.6.3, are compared with what occurred. Where the organisation predicted that a control would detect an action and it did not, the difference is recorded as a finding.

F1.4 Findings

F1.4.1 Structure

F1.4.1.1 Each finding is recorded on pro forma T09 and states: identifier; title; severity; category; the capability level at which it is reachable; affected assets; description; the technique by which it was exploited; evidence reference; mission impact; root cause; recommendation; detection opportunity; owner; target date; and method of retest.

F1.4.1.2 A finding is titled as a defect and not as an achievement.

F1.4.1.3 Two fields are consistently the weakest in immature reporting.

- a. **Root cause.** A symptom restated is not a root cause. The absence of a compensating control, because ownership of a class of account was never assigned, is a root cause. A weak password policy is a symptom. Correction of symptoms reproduces the finding at the next engagement.
- b. **Detection opportunity.** Not every weakness can be prevented at acceptable cost. Every finding that cannot be prevented economically shall carry a detection recommendation, so that the defensive element has an available action while the structural correction is scheduled.

F1.4.2 Controls that functioned

F1.4.2.1 Every report shall record the controls that prevented, delayed or detected activity; the detections that operated correctly; the response actions that were correct and timely; and the design decisions that constrained the engagement.

F1.4.2.2 This is required for two reasons. It is accurate, and a report omitting it is not. It is also the only mechanism by which an organisation establishes which of its investments are effective.

F1.4.3 Reference to personnel

F1.4.3.1 Findings describe appointments and procedures. Individuals are not named.

F1.4.3.2 No material shall be included that could support disciplinary or administrative action.

F1.4.3.3 Social engineering results are reported as rates. Individual results are not reported.

F1.4.3.4 Human factors are recorded as procedural or training matters. A person who responded to a well-constructed approach under time pressure has demonstrated a gap in the control that permitted the approach to arrive.

F1.5 Severity

F1.5.1 Severity is a function of mission impact and of exploitability in the environment assessed. It is not derived from a published vulnerability score.

Severity	Meaning	Expectation
Critical	Directly enables loss of a critical service, compromise of a substantial data holding, or administrative control of the estate, achievable by the emulated adversary without significant obstacle	Days
High	Enables significant compromise, or constitutes a major step toward an objective, achievable with moderate effort	Weeks
Medium	Contributes to an attack path but requires further conditions; or a detection gap for a significant technique	Next planning cycle
Low	Minor weakness or hardening opportunity; or a detection gap for a technique of limited value	Backlog
Informational	No direct risk. Observation of interest.	Awareness

F1.5.2 Severity is assessed by the red team and may be disputed by the assessed organisation. A dispute is recorded in the report with both positions stated. Severity shall not be amended without record.

F1.5.3 Severity is read against the capability level emulated. A finding reachable at level 1 is more urgent than the same finding reachable only at level 3, because a greater number of adversaries can reach it. The level is stated in the report.

F1.6 Debriefs

F1.6.1 Technical debrief

F1.6.1.1 Held with the operators, the defensive element, detection engineering and the relevant system owners, before the report is issued. Two to four hours.

F1.6.1.2 The narrative is walked chronologically. At each step the defensive element states what was observed, and the actual sequence is then presented.

F1.6.1.3 The following apply.

- Command is not present. The defensive element must be able to state that an action was not observed, without consequence.
- No individual is identified. The facilitator enforces this.
- Detection engineering attends with access to its query interface and constructs the first detection during the debrief.
- Actions are recorded with owners.

F1.6.1.4 The greater part of the value of an engagement is transferred at this debrief, and the report becomes more accurate as a result. The defensive element frequently holds telemetry of which the red team was unaware, which alters findings.

F1.6.2 Command brief

F1.6.2.1 Held with the Approving Authority, security leadership and the relevant capability owners, with or shortly after the report. Thirty to forty-five minutes.

F1.6.2.2 Sequence: the question the engagement was required to answer; what was conducted; what occurred; which controls functioned; which did not, in order; the recommendations and their cost; the decisions required.

F1.6.2.3 The following apply.

- a. Mission impact is stated before technique.
 - b. One attack path diagram is presented.
 - c. Live demonstration is not conducted. It displaces the question of what is to be corrected.
 - d. The brief concludes with the decisions required of the audience.
-

F1.7 Distribution and handling

F1.7.1 The report carries the classification of the most sensitive material it references.

F1.7.2 The distribution list is defined in the Rules of Engagement and states named individuals or named appointments.

F1.7.3 Reports are distributed encrypted or through a controlled platform.

F1.7.4 The defensive element receives the activity record at culmination and the report after the engagement closes.

F1.7.5 Retention is as set in the Rules of Engagement, followed by destruction and a certificate. Reports are not released outside the distribution list without the approval of the Approving Authority.

F1.8 Remediation and retest

F1.8.1 The red team advises on remediation. It does not implement. It does track.

Stage	Owner	Standard
Finding entered in the risk register	Trusted Agent	Within 10 working days of issue
Owner and target date assigned	System owner	Within 10 working days
Remediation implemented	System owner	Per the severity expectation
Completion notified	System owner	To the red team
Retest	Red team	Within 20 working days of notification
Closure	Red team	Only following a passed retest

F1.8.2 A finding is closed by a passed retest and not by the closure of a task.

F1.8.3 Where the organisation elects not to remediate, the decision is recorded as a formal acceptance of risk, signed by the Approving Authority, with a review date. The finding remains open.

F1.9 Verification before issue

F1.9.1 The Reviewing Officer confirms the following before the report is issued.

1. The summary is comprehensible in isolation, does not exceed two pages, and is free of technical terminology.
2. Every claim is traceable to referenced evidence.
3. Controls that functioned are recorded.
4. Every narrative step carries a defensive observation.
5. Coverage gaps are recorded in the three categories at paragraph F1.3.2.
6. No individual is identified.
7. No credential, token, key or bulk sensitive data appears anywhere, including appendices.
8. Screenshots are redacted and carry a visible time reference.
9. Severity assessments are internally consistent.
10. Every finding states a root cause and not a restated symptom.
11. Every finding has an owner, a target date and a method of retest.
12. Findings that cannot be prevented economically carry a detection recommendation.
13. The capability level emulated is stated.
14. The activity record and cleanup attestation are attached.
15. Classification and distribution are correct.
16. The Reviewing Officer did not execute the engagement.
17. Evidence identifiers, hashes and repository references reconcile with the evidence index.
18. Measures state their sample, exclusions, missing or censored observations, and data limitations.

PART F2 — MEASURES AND MATURITY

F2.1 Principle

F2.1.1 The red team is an instrument of measurement. Its effectiveness is judged by the improvement of the defence and not by its own performance during engagements.

F2.1.2 Measures expressed in terms of red team achievement produce three effects: a red team rewarded for success selects easier targets; a defensive element penalised for failure conceals incidents and disputes findings; and command receives a score rather than an assessment of risk. The prohibition is at paragraph 3.7 of the methodology.

F2.2 Measures recorded per engagement

F2.2.1 Timing

Measure	Definition
Time to telemetry	Defined red action start event to the first usable defensive event attributable to it
Time to alert	Defined red action start event to the first alert attributable to it
Time to examination	Alert creation to the first evidenced analyst examination
Time to respond	First evidenced analyst examination to the first effective containment action
Time to contain	Defined red action start event to evidenced removal of the assessed adversary access
Time to recover	First containment action to restoration of the affected service or control to the agreed state
Presence	Initial access event to evidenced removal of the assessed adversary access

F2.2.1.1 The start and end event for each timing measure is defined before execution. These are recorded

by action or technique and not only for the engagement as a whole. A single figure conceals the distinction between a technique detected promptly and one not detected at all.

F2.2.1.2 An event not observed before the end of the measurement window is reported as not observed or right-censored, with the window stated. It is not recorded as zero and is not silently omitted. A summary states the count, sample size, median and range and identifies censored observations. A mean is used only where the distribution and sample size make it meaningful, and never without the sample size.

F2.2.2 Coverage

Measure	Definition
Attempt status	Planned techniques attempted, not attempted or substituted, with reason
Prevention	Attempted techniques blocked before the intended effect, divided by techniques attempted
Execution	Attempted techniques achieving the intended technical effect, divided by techniques attempted
Telemetry	Executed or blocked actions producing usable telemetry, divided by applicable actions
Detection	Applicable actions generating a relevant alert, divided by applicable actions
Examination	Alerts examined, divided by alerts generated
Containment	Executed actions effectively contained within the agreed window, divided by executed actions requiring containment
Recovery	Containment cases restored to the agreed state, divided by cases requiring recovery
Gap profile	Distribution across the three categories at paragraph F1.3.2

F2.2.2.1 Every ratio states its numerator, denominator, exclusions and count. A technique is not counted as a detection opportunity where the planned action was not attempted, was substituted, or was blocked before the relevant signal could exist. Prevention, telemetry, alerting, investigation, containment and recovery are distinct control outcomes.

F2.2.3 Outcome and remediation

Measure	Definition
Objectives achieved and prevented	By objective, with the route or the control concerned
Controls that engaged	Controls that prevented, delayed or detected activity
Findings by severity	Distribution
Closure	Findings closed by retest, divided by findings raised
Time to closure	Median days from issue to verified correction, by severity
Recurrence	Findings reappearing at a subsequent engagement

F2.2.3.1 Recurrence requires a documented basis of comparison. A similar title is not sufficient: the control objective, affected environment, attack condition and expected correction are considered. A finding is reported as untested where a later engagement did not exercise the corrected condition.

F2.2.4 Social engineering

F2.2.4.1 Recorded as rates. Individual results are not recorded.

Measure	Significance
Delivery rate	Campaign-specific evidence of filtering and delivery; not a general gateway score
Engagement rate	Proportion of recipients taking the defined interaction, with automated and duplicate activity excluded
Submission rate	Proportion of recipients reaching the defined submission event; real credentials are not required
Reporting rate	Proportion of recipients reporting the approach
Time to first report	Delivery to the first report by a recipient

F2.2.4.2 The reporting rate and the time to first report are the significant figures. A substantial engagement rate accompanied by prompt and widespread reporting indicates that the approach was contained by personnel. A low engagement rate with no reporting does not. The denominator, duplicate handling, automated security-tool interactions, delivery failures and measurement window are stated.

F2.2.5 Measure specification and data quality

F2.2.5.1 Each reported measure has a specification approved at Gate G3. The specification records:

- measure identifier, decision or objective served, and accountable owner;
- definition, unit, numerator and denominator or start and end events;
- source systems, collection method, measurement window and frequency;
- inclusion, exclusion and substitution rules;
- target or expected range and the rationale for it, where a target is useful;
- sample size, missing data, censored observations and known uncertainty;
- validation method, reviewer and date;
- applicable environment, scenario, threat profile and ATT&CK release; and
- retention, classification and reporting format.

F2.2.5.2 The Red Team Lead and the defensive data owner reconcile timestamps, action IDs and source records before calculation. Manual adjustments remain visible and attributable. A measure that fails its stated quality threshold is reported with the limitation or is withheld; it is not presented as precise.

F2.2.5.3 Targets are locally approved and risk-based. They are not imported from another organisation without establishing that the service, threat, measurement window and data quality are comparable. Measures are reviewed for incentives: a measure shall not reward noise, superficial rule creation, premature ticket closure or avoidance of difficult tests.

F2.3 Programme measures

F2.3.1 Recorded across engagements and reported quarterly.

Measure	Direction sought
Validated detection coverage for comparable actions	Improving toward the locally approved risk-based target
Time to alert, examination, containment and recovery for comparable actions	Improving toward the locally approved risk-based target
Closure by passed retest	Improving toward the locally approved risk-based target
Time to verified closure by severity	Improving, subject to risk and remediation complexity
Validated recurrence	Decreasing, with untested corrections shown separately

Measure	Direction sought
Defensive improvements verified by replay or retest	Increasing in effectiveness, not merely in count
Findings accepted rather than corrected	Monitored. A rising proportion indicates findings that cannot be acted upon, or disagreement with the severity assessed.
Engagements requested rather than directed	Increasing

F2.3.2 No single measure is the universal indicator of programme effectiveness. Validated recurrence is important where a correction has genuinely been retested. Other required views are mission-risk reduction, response improvement, verified remediation, breadth of risk coverage and the quality of the underlying evidence.

F2.3.3 Trends combine only comparable observations. The quarterly report states material changes in scope, threat, procedure, defensive architecture, measurement window, ATT&CK release and data source. Where comparability is weak, results are presented as separate case evidence rather than as a trend line.

F2.4 Quarterly report

F2.4.1 One page, submitted to the Approving Authority, covering:

- engagements conducted during the quarter, one line each;
- coverage across comparable engagements, or separate case results where comparison is not valid;
- the gap profile with owners;
- findings raised, closed, overdue and accepted;
- any recurrence, and its cause;
- defensive improvements attributable to red team activity;
- decisions required.

F2.4.2 Sub-paragraph f is recorded from the outset. Attribution of those improvements is not made elsewhere.

F2.5 Maturity

F2.5.1 Maturity is assessed annually across four domains at three levels.

F2.5.2 Programme

Level	Criteria
1 Defined	Aim and objectives documented and approved. Engagements recorded. Findings tracked. A programme exists.
2 Managed	The wider organisation understands the function. Engagements produce consistent tactical improvement. Measures reported on a cycle.
3 Optimised	Engagements selected against the organisation's principal risks. Outputs influence resourcing decisions.

F2.5.3 Personnel

Level	Criteria
1 Defined	Appointments documented. Capability partly dependent on external support.
2 Managed	Internal expertise in the technology actually in use. A skills matrix and training plan exist.
3 Optimised	Specialists across disciplines, with the ability to draw in domain expertise by design rather than by necessity.

F2.5.4 Process

Level	Criteria
1 Defined	Rules of Engagement for every engagement. Lifecycle and gates observed.
2 Managed	Threat profiles drive scenarios. Engagements planned against a calendar. Legal integrated into planning. Retest cycle operating.
3 Optimised	Engagements selected in the context of principal risks. Full technique mapping and coverage measurement. Purple replay integrated as standard.

F2.5.5 Technology

Level	Criteria
1 Defined	Established tooling. Manually constructed infrastructure. Manual records.
2 Managed	Automated infrastructure deployment. Automatic operator and infrastructure records. Laboratory environment for technique testing.
3 Optimised	Custom capability where the threat profile requires it. Automated reporting and evidence collection.

F2.5.6 Level 1 across all four domains constitutes a functioning capability. Level 2 is a legitimate destination.

F2.5.7 The technology domain shall not be advanced beyond level 1 before the process domain has reached level 2. Custom capability in an organisation without an established retest cycle does not improve defensive outcomes, and is the most common misallocation of effort in this field.

ANNEX G — LEGAL, SAFETY AND DATA HANDLING

Supporting Chapters 4, 5 and 8 of the Red Team Methodology. Issued under the authority of the Head of Red Team.

This annex states a framework. It is not legal advice. Every engagement requires review by a qualified legal adviser against the law applicable to the jurisdiction and to the organisation. The instruments at paragraph G.2 shall be identified by that adviser and recorded before the methodology is approved.

G.1 Legal exposure and individual protection

G.1.1 Red team activity may engage offences and civil, regulatory, contractual, employment, privacy and professional obligations. Written, target-specific authorisation from a person competent to give it is a

necessary control, but it may not by itself make every planned activity permissible. Qualified counsel shall establish the complete position for the relevant jurisdictions, parties, systems and techniques.

G.1.2 Defective or incomplete authority may expose the organisation, approving persons, providers and individual operators. The allocation of liability depends on the applicable law and facts and is not determined by this publication. This is why the Rules of Engagement are treated as absolute at Annex B, self-authorisation is prohibited at Annex A, and every operator holds a protected right of refusal.

G.2 Legal framework

G.2.1 The following categories of instrument bear on red team activity. The specific instruments applicable, and their references, shall be identified by the legal adviser and recorded in a schedule held with this annex.

Area	Bearing on the activity
Unauthorised access to computer systems	Authority and consent may determine whether access is unauthorised; counsel establishes the effect and any remaining offences or duties
Interception of communications	Constrains capture of network traffic
Defence mandate or equivalent instrument	The authority to assess another organisation. The governing instrument for external engagements.
Regulation of personnel and discipline	Bears on social engineering directed at members of the organisation
Protection of classified information	Where the engagement touches classified systems. See Annex I.
Data protection	Personal data encountered during an engagement. Any derogation applicable to defence or national security shall be established and not assumed.
Monitoring of personnel	Constrains social engineering and observation of personnel. May differ between service and civilian staff.
Critical infrastructure	Where assessing infrastructure outside the organisation under mandate
Alliance and coalition arrangements	Where systems or information belonging to another nation are in scope
Cross-border activity	Where infrastructure, operators or targets are in different jurisdictions
Operational effects	Cited only to mark the boundary this publication does not cross. See Chapter 2, paragraphs 2.10 to 2.14.

G.2.2 Applicability is determined instrument by instrument. DORA and its delegated TLPT regulation apply only where their legal criteria are met; CBEST applies where the relevant United Kingdom authorities direct it; and TIBER-EU is a sector-agnostic framework that may be adopted voluntarily or through a national, European or supervisory implementation. None shall be presented as binding merely because this methodology uses it as a benchmark. See Annex K.

G.2.3 Cross-border activity

G.2.3.1 Where infrastructure, operators or targets are in different jurisdictions, activity may constitute an offence in a jurisdiction that has not been considered. Before an engagement with a cross-border element, the following shall be established.

- The physical location of the target systems, including the region of any hosted service.
- The location of engagement infrastructure.
- The physical location of each operator during execution.
- Whether data will cross a border, and on what basis.

- e. Whether the current terms and testing policy of every hosting or software provider permit the activity as both a source and a target. Requirements differ by provider, service and activity and may include prior approval. Breach may cause interruption or termination during execution.

G.2.4 Authority to direct and authority to consent

G.2.4.1 The distinction most frequently mistaken in an organisation with a command structure is the following.

- a. **Command authority** is the power to direct that an assessment be conducted.
- b. **System authority** is the power to consent to access to a particular system.

G.2.4.2 A tasking order establishes the first. It does not establish the second unless the instrument creating the mandate expressly confers it. Where the two are held by different bodies, both are required. System authority records the required consent to access, subject to every other applicable legal, contractual and provider condition.

G.2.4.3 The position shall be established in writing before phase 1 is complete. See Annex H, part H2.

G.2.5 Applicability and permission record

G.2.5.1 The legal adviser maintains an engagement-specific applicability record. For each law, regulation, mandate, contract, employment or consultation obligation, classification rule, insurance term and provider policy considered, it records: exact title and edition or effective date; jurisdiction and subject; whether it applies; the basis for that decision; the required control or deliverable; accountable owner; evidence of completion; and the event that requires re-review. “Not applicable” is a reasoned decision, not a blank field.

G.2.5.2 A provider and third-party permission register is attached where any hosted, managed or shared service is a source, target or dependency. One row per provider and service records:

- a. provider, service, account, tenant, subscription, project and resource identifiers;
- b. whether the organisation owns the resource or has direct written permission from its owner, including the consenting name and authority;
- c. current policy title, URL, version or effective date, and the date checked;
- d. permitted and prohibited activity, service-specific limits and rate limits;
- e. any notification, approval, simulated-event form or support case and its validity period;
- f. security, abuse and emergency contacts, region and jurisdiction; and
- g. the operator who rechecked the policy no more than twenty-four hours before execution.

G.2.5.3 A previous engagement’s approval or a general statement that penetration testing is allowed shall not be reused without revalidation. Cloud and software service policies change independently of this publication.

G.2.5.4 The following is an orientation snapshot at the source-baseline date, not standing permission. The linked policy and controlling terms shall be read in full for the exact service and activity.

Provider	Current decision points to verify
AWS	Listed customer services may be assessed without prior approval, but all C2 requires prior approval. Covert adversarial simulation, simulated phishing, malware testing and other simulated events may require the Simulated Events process, submitted at least two weeks in advance. DoS and related flooding remain prohibited except through a separate applicable policy.

Provider	Current decision points to verify
Microsoft Azure	Ordinary testing of owned or expressly authorised resources does not require preapproval, but the current Microsoft Cloud Unified Penetration Testing Rules of Engagement control. DoS, access to resources or secrets without permission, excessive traffic and specified social-engineering uses are prohibited. Microsoft may interrupt activity detected as abuse.
Google Cloud	Penetration testing of the customer's own projects does not require notification, but it remains subject to the Acceptable Use Policy and Terms of Service and shall not affect another customer's application.

G.2.5.5 The team records the policy conclusion, not merely a link: source and target use, service eligibility, prohibited features, notice or case number, validity window, rate limits, abuse response and the action required if provider infrastructure is reached.

G.3 The authorisation chain

G.3.1 Three documents are required and each performs a distinct function.

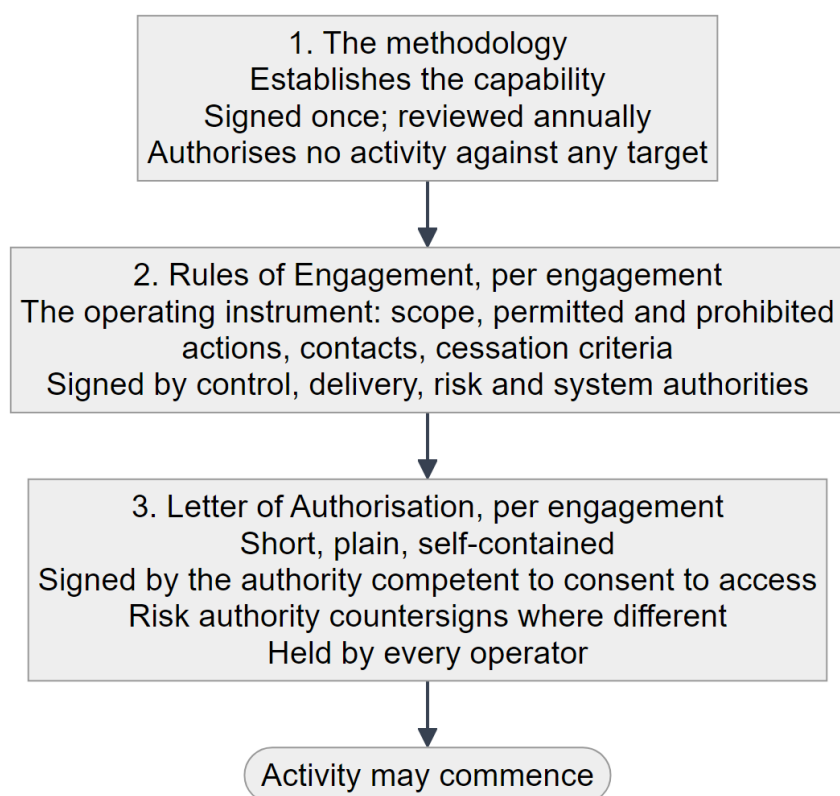


Figure G-1. Authorisation chain

G.3.2 The Letter of Authorisation

G.3.2.1 Produced on pro forma T10. The following are required.

- a. Signature by each person holding actual authority to consent to access to the systems in scope. Where operational risk authority is held separately, the Approving Authority countersigns.
- b. A plain statement of who is authorised, to do what, against what, between which dates, and whom to contact for verification.

- c. Sufficient brevity to be read and understood in under a minute by a police officer, a security guard, or a systems administrator.
- d. Comprehensibility without reference to the Rules of Engagement. The letter stands alone.
- e. Possession by every operator, in physical and electronic form, for the duration of the engagement.

G.3.2.2 The authority of every signatory shall be verified and not assumed. An invalid or incomplete signature may not provide the intended consent or protection. Where systems belong to a different entity, division or agency, that entity's system authority is required.

G.3.3 The verification card

G.3.3.1 Separate from the Letter of Authorisation, and carried by each operator, particularly where activity is conducted on site. It contains only:

- a. a statement that the bearer is conducting authorised security testing;
- b. the engagement reference;
- c. the name and continuously answered telephone number of the Approving Authority;
- d. the name and continuously answered telephone number of the Trusted Agent.

G.3.3.2 Nothing further is included. The card exists to permit de-escalation and rapid verification by a person who has detained the operator. Any additional detail constitutes intelligence provided to that person.

G.3.3.3 Where physical entry is authorised, the Trusted Agent shall confirm before execution that site security leadership and, where appropriate, law enforcement liaison have been informed that authorised activity will occur during the period, without disclosure of timing or method.

G.4 Data protection

G.4.1 Principles

Principle	Application
Lawful basis	The processing of personal data during the engagement has a recorded lawful basis, confirmed by the legal adviser
Minimisation	The minimum personal data required to demonstrate impact. Markers and schemas are preferred to records.
Purpose limitation	Data encountered is used only to demonstrate the finding
Storage limitation	Retained only for the period set in the Rules of Engagement, then destroyed with a certificate
Security	The evidence repository is encrypted, access-controlled and logged
Accountability	Every access to sensitive data is recorded in the operator record

G.4.2 Requirements

G.4.2.1 A personal data set shall not be exfiltrated. Reachability is demonstrated by a count of records, a schema, or a single redacted illustrative record.

G.4.2.2 Special category data, including data concerning health, biometrics, political opinion, religion, sexual orientation or trade union membership, shall not be intentionally collected or retained as evidence. Incidental viewing, logging or capture may itself be processing and shall be minimised, stopped, reported and handled under the lawful-basis and incident procedure. The fact and identity of the store may be recorded; its contents are not.

G.4.2.3 Personal data shall not be retained beyond the retention period, and its destruction shall be recorded.

G.4.2.4 Inadvertent access to a bulk data set shall be reported to the Trusted Agent immediately. The data protection officer or legal adviser shall determine controller and processor roles, whether a personal data breach has occurred, when the organisation became aware for the purpose of any deadline, and which notification or documentation duty follows. The red team shall not delay escalation while making that determination.

G.4.2.5 Before authorisation, the legal adviser or data protection officer records: the controller and any processor or joint-controller roles; lawful basis; categories and sources of personal data; recipients and access; retention and verified deletion; international transfers and safeguards; data-subject information or any lawful restriction; and whether a data protection impact assessment or prior consultation is required. Where one is required, it is completed before execution.

G.4.3 Classified information

G.4.3.1 Where activity encounters classified material, the classification regime governs and outranks every other provision of this annex.

- a. Classified material shall not be moved to a system not accredited for it, including operator systems, the evidence repository and the report.
- b. Where access to classified material is demonstrated, the fact and the location are recorded. The content is not.
- c. Engagement artefacts take the classification of the material they describe, at the time they are created.
- d. Deliverables shall be assessed for aggregation before classification is assigned. A complete account of an estate's weaknesses is more sensitive than any single weakness within it.
- e. A suspected spill shall be reported immediately under the organisation's procedure, before any engagement consideration, and the engagement ceases.
- f. Classification is assigned by the security authority and not by the red team.

G.4.3.2 The full controls are at Annex I, paragraph I.2.

G.4.4 Personnel data and social engineering

G.4.4.1 Social engineering processes the personal data of personnel and may engage monitoring law and consultation requirements.

G.4.4.2 Before any social engineering activity:

- a. the legal adviser confirms the lawful basis and any consultation obligation;
- b. individual results shall not be disclosed to management, per Annex F paragraph F1.4.3;
- c. captured credentials are hashed or truncated and destroyed at closure;
- d. the target population is defined by group, and the exclusion list is observed absolutely.

G.5 Safety

G.5.1 Principle

G.5.1.1 Where realism conflicts with the safety of personnel, systems, data or operational readiness, realism yields. This applies without exception and without a requirement to seek approval to proceed.

G.5.1.2 This is not a limitation upon the value of an engagement. Where an adversary would cause harm that the red team will not cause, the difference is described in the report. It is not a gap to be closed by causing the harm.

G.5.2 Safety-critical environments

G.5.2.1 Where the scope includes operational technology, industrial control, medical devices, transport, energy, or any system whose failure can injure a person, the following apply.

	Requirement
1	Safety instrumented systems and protection systems are permanently outside scope
2	Active scanning and enumeration of control protocols require approval per technique; such devices fail unpredictably under ordinary scanning
3	A representative non-production environment is required before any technique is used against a live system
4	The asset owner and a safety engineer participate in scoping and are reachable throughout execution
5	Activity occurs only during agreed windows, with the process in a known-safe state
6	Engineering staff able to intervene physically are present and briefed
7	Any anomaly in the physical process causes activity to cease, irrespective of cause
8	Where the boundary between general-purpose and control networks is the objective, activity stops at the boundary and demonstrates reachability, unless crossing is expressly authorised with a safety case

G.5.2.2 Requirement 8 is ordinarily the correct course. Demonstrating that a control network is reachable from a general-purpose network constitutes the finding. Entry adds risk and little information.

G.5.3 Availability

G.5.3.1 Denial of service and resource exhaustion are prohibited by default.

G.5.3.2 Rate limits for scanning and credential attacks are set in the Rules of Engagement and observed.

G.5.3.3 Account lockout thresholds are established before any credential attack. Password spraying is rate-limited below the threshold with a margin.

G.5.3.4 Change freezes, periods of financial close and major operational events are observed.

G.5.3.5 Suspected degradation causes activity to cease, whether or not the red team is believed to be the cause.

G.5.4 Safety of operators

G.5.4.1 Activity conducted on site requires a second person aware of the operator's location and status, with agreed intervals for contact.

G.5.4.2 An operator who is challenged shall not resist, evade or withdraw. The operator ceases activity, identifies the activity as authorised security testing, produces the verification card, and requests that the Approving Authority be contacted.

G.5.4.3 No operator is required to undertake activity judged personally unsafe. Refusal on that ground carries no consequence.

G.6 Discovery of a genuine intrusion

G.6.1 The operational procedure is at Annex E, paragraph E.5.5. The legal considerations are as follows.

- a. Discovery may engage mandatory notification obligations with short statutory periods. The legal adviser and incident process determine the point of awareness and the applicable deadline. The red team escalates immediately and does not await confirmation.

- b. Evidence is preserved in its original state. Red team activity records form part of the incident record and may be disclosed to a regulator or in proceedings. This is a further reason the recording standard at Annex E is not discretionary.
- c. The red team does not investigate, remediate, or further interact with the affected systems.
- d. The legal adviser and the Approving Authority are informed immediately, in that order of urgency.

G.7 Personnel security

G.7.1 A red team holds capability, access and knowledge that constitute a concentrated insider risk. The following controls apply.

Control	Requirement
Clearance	All members hold clearance to the level required by the environments assessed, revalidated under the applicable policy
Segregation	No red team member holds standing privileged access to production systems
Two-person rule	High-risk actions require consultation with a second operator, per Annex E paragraph E.2.1
Independent records	Infrastructure and session capture are automatic and not modifiable by operators
Tooling control	Offensive tooling is held on controlled systems, inventoried, and not on personal devices
Credentials	Captured credentials are destroyed at closure, and the destruction recorded
Departure	On departure, access is revoked, tooling returned, access to evidence removed, and continuing obligations reaffirmed in writing
Audit	Engagement records are audited annually against this methodology by a party independent of the red team

G.8 Professional conduct

G.8.1 The following bind every member.

- a. Operate only under valid authorisation.
- b. Remain within scope. Ambiguity requires cessation and consultation.
- c. Report truthfully, including errors made by the red team and controls that defeated it.
- d. Protect the confidentiality of all matters learned, permanently, including after departure.
- e. Do not employ capability or knowledge obtained during an engagement for personal benefit or outside an authorised engagement.
- f. Do not target individuals personally, and do not provide material for disciplinary use.
- g. Declare conflicts of interest, including prior employment, personal relationships and financial interest in an assessed organisation or in a product being assessed.
- h. Refuse activity that is unlawful, unsafe or unethical, and report the refusal. Refusal on these grounds is protected.
- i. Do not publish, present or discuss engagement material externally without the written approval of the Approving Authority, including material presented as anonymised.
- j. Maintain competence. A technique used in a live environment shall be understood and not copied.

G.9 Verification before authorisation

G.9.1 The Red Team Lead, with the legal adviser, confirms the following at gate G1. The completed record is attached to the Rules of Engagement.

1. The authorisation chain is verified: the signatory holds actual authority over every system in scope.
2. The Letter of Authorisation is signed, dated, and covers the whole execution period.
3. Every operator holds the Letter of Authorisation and the verification card.
4. The lawful basis for processing personal data is recorded.
5. Monitoring and consultation obligations are addressed, where social engineering is authorised.
6. Third-party and system-owner consent is obtained where scope touches their systems.
7. The provider and third-party permission register at paragraph G.2.5 is complete, and each policy has been rechecked within twenty-four hours of execution.
8. Cross-border implications are assessed for target, infrastructure and operator locations.
9. Notification obligations, awareness rules and internal escalation routes are identified.
10. Requirements for the handling of classified information are addressed.
11. Safety-critical systems are identified and excluded, or a safety case exists.
12. Where physical entry is authorised, site security and law enforcement liaison are informed.
13. Controller and processor roles, lawful basis, transfers, retention and deletion are recorded; the need for a data protection impact assessment has been decided.
14. The retention period and method of destruction are agreed and recorded.
15. Evidence handling meets any potential requirement for disclosure.
16. The legal adviser has recorded approval and any limitations.

ANNEX H — CATEGORIES OF ENGAGEMENT

Supporting Chapter 4 of the Red Team Methodology. Issued under the authority of the Head of Red Team.

The methodology applies in full to every category. This annex records only what differs.

Part	Category	Applies to
H1	SL-1 Internal assessment	Assessment of the organisation's own systems
H2	SL-2 Mandated engagement	Assessment of another organisation under mandate
H3	SL-3 Exercise	Red team element within a structured exercise
H4	SL-4 Purple team	Open activity conducted with the defensive element

PART H1 — INTERNAL ASSESSMENT

H1.1 Characteristics

Customer	The organisation's own command
Approving Authority	An officer of the organisation, outside the chain of command assessed
Ordinarily covert	Yes
Basis	Internal authorisation from the system authority
Principal value	Assessment of the organisation's own detection and response

H1.2 The risk of the simplified authority model

H1.2.1 Internal assessment has the simplest legal basis: the organisation authorises assessment of its own systems. There is no external party, no agreement, and no question of authority between entities.

H1.2.2 That simplicity invites curtailment of process. Rules of Engagement are omitted, the Letter of Authorisation is treated as unnecessary, or the head of the assessed element signs the authorisation for its own assessment. Each converts a straightforward engagement into personal liability and an unusable result.

H1.2.3 The controls at Annexes B and G apply in full to internal assessment. There is no reduced variant.

H1.3 Variations

H1.3.1 Approving Authority

H1.3.1.1 The common internal failure is that the Approving Authority sits within the chain of command assessed.

Subject of assessment	Competent Approving Authority
The detection capability	An officer above, or outside, the defensive element. Not its head.
The information technology estate	The officer accountable for the risk to that estate. Not its manager.
The organisation as a whole	The commander, or the officer holding the risk

H1.3.2 Trusted Agent

H1.3.2.1 The Trusted Agent shall be internal, senior, and not a member of the element assessed. Suitable appointments ordinarily include the head of risk, the head of compliance, a deputy security officer not responsible for the defensive element, or a director from a different domain.

H1.3.2.2 Where the only technically competent candidate sits within the assessed element, the engagement shall either reduce scope so that the candidate is no longer assessed, or adopt a two-person arrangement: a senior decision-maker holding the authority to suspend, and a technical adviser who does not receive engagement detail.

H1.3.3 Compartmentalisation

H1.3.3.1 The cleared list is recorded. Each addition is recorded with the date and the authorising appointment.

Appointment	Cleared	Basis
Approving Authority	Yes	Accepts the risk
Trusted Agent	Yes	Controls the engagement
Legal adviser	Yes	Advises on authorisation
Head of security	Only where not part of the capability assessed	
Head of the defensive element	No, in a covert engagement	The element is the subject of assessment
Owners of excluded systems	Partial: informed only that assessment is occurring and that their system is excluded	
Service desk	No	Its response forms part of the assessment

H1.3.4 Internal knowledge

H1.3.4.1 An internal red team holds knowledge unavailable to an external adversary: architecture, the location of credentials, undocumented systems, and the identity of suitable targets for social engineering.

H1.3.4.2 The engagement plan shall record which knowledge derived from internal privilege rather than from reconnaissance. Privileged knowledge that the emulated adversary could not plausibly obtain shall not be used, unless the scenario expressly models an insider at capability level 4.

H1.3.4.3 Where privileged knowledge is used to reduce time, the report shall state it, because it alters the meaning of the result. The report records the additional reconnaissance an external adversary would have required, and the detection window is read against that figure.

H1.3.5 Existing access

H1.3.5.1 Red team members frequently hold, or have held, legitimate access to internal systems.

- a. Red team members shall not hold standing privileged access to production systems.
- b. An operator's own legitimate accounts shall not be used during an engagement.
- c. Engagement access is separate, created for the purpose, recorded in the Rules of Engagement, and removed at cleanup.
- d. Where an operator previously administered a system in scope, that operator is excluded from that part of the engagement.

H1.4 Progression

H1.4.1 The following sequence is recommended for a capability commencing internal assessment.

Engagement	Scope	Starting posture	Covert	Execution
First	One service, one objective	Assumed breach, user workstation	Partially: the Trusted Agent and one senior member of the defensive element are aware	5 days
Second	The same service, with an additional objective	Assumed breach, user workstation	Yes	10 days
Third	Two services, identity focus	Assumed breach, user workstation	Yes	10 days
Fourth	Full scope with exclusions	External and assumed breach in parallel	Yes	15 days

H1.4.2 The first engagement is only partially covert by design. Conducting the first engagement fully covert means that the deconfliction procedure is first exercised on the occasion when it matters. The procedure is proven while it is being observed.

H1.5 Additional cessation criteria

H1.5.1 In addition to those at Chapter 8, paragraph 8.15.

- a. Activity risks affecting a live operational commitment or mission task.
- b. An internal element escalates to an external party.
- c. Engagement activity is discussed in a forum that would compromise its confidentiality.
- d. A member of personnel experiences significant distress as a result of engagement activity.
- e. The independence of the Trusted Agent is compromised, including by reassignment into the assessed element.

H1.6 Conduct of the internal relationship

H1.6.1 The recurring difficulty in internal assessment is institutional rather than legal. The red team continues to work alongside the element it assesses.

Practice	Basis
Debrief the defensive element before command	The element shall not learn of a finding from a briefing to command
Conduct the technical debrief without command present	Per Annex F, paragraph F1.6.1
Attribute success openly; deliver findings privately	Controls that functioned may be reported widely; failures are delivered to the owner
Admit the defensive element to purple team activity	Establishes the red team as a resource rather than an inspectorate
Do not characterise an engagement as a success for the red team	In any forum, including informally
Provide the activity record at culmination	Before the report. The element identifies its own gaps, which is a more effective form of instruction.

PART H2 — MANDATED ENGAGEMENT

This category carries the greatest legal and institutional risk and is the least tolerant of procedural error. It shall not be undertaken until the procedures are established in practice and the legal framework at Annex G is confirmed.

H2.1 The governing distinction

H2.1.1 In internal assessment, the organisation authorising the assessment owns the systems assessed. In a mandated engagement it may not, and the authority to consent belongs to the owner of the systems rather than to the body issuing the tasking.

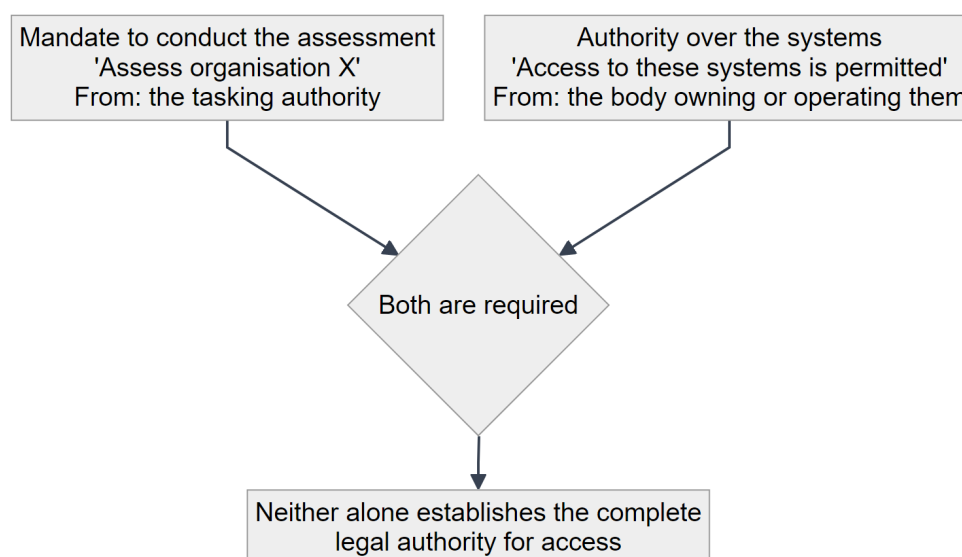


Figure H-1. Mandate and system authority

H2.1.2 A tasking order from a chain of command does not of itself authorise access to another organisation's systems, unless the instrument creating the mandate expressly confers that power. The applicable position is established in writing before phase 1 completes. See Annex G, paragraph G.2.4.

H2.1.3 Where the assessed organisation is a civil body, the exercise of authority over it is legally and institutionally sensitive even where a mandate exists. The instrument shall be identified by reference and confirmed by the legal adviser. The consent of the civil body should be obtained wherever the mandate permits, even where it is not required. Consent obtained produces cooperation; consent compelled removes it for every subsequent engagement.

H2.2 Authority models

H2.2.1 The applicable model is determined and recorded in the Rules of Engagement.

Model	Basis	Required
A. Statutory power	Law confers the authority to assess	The statutory reference, legal confirmation that it applies, and any notification the statute requires
B. Consent	The organisation agrees to be assessed	A signed agreement and a Letter of Authorisation from its own competent authority
C. Directed with consent	A superior authority directs the assessment and the organisation consents	Both the tasking instrument and the organisation's Letter of Authorisation
D. Directed without consent	A superior authority directs the assessment over the organisation's objection	Express legal authority, identified by reference, confirmed in writing by legal counsel, with the risk accepted in writing by the tasking authority

H2.2.2 Model D shall not be accepted on assurance alone.

H2.3 Additional requirements at phase 1

H2.3.1 In addition to gate G1 at Annex C, paragraph C.5.3.

1. The authority model is determined and recorded.
2. The legal instrument or agreement is identified by reference and reviewed by counsel.

3. The signatory's authority over the specific systems is verified, not assumed.
4. A written agreement allocates liability and records any indemnity required by counsel.
5. Non-disclosure obligations are executed in both directions.
6. The assessed organisation's Trusted Agent is appointed, named and briefed.
7. The assessed organisation's system owners have confirmed the exclusion list.
8. Third-party and hosting provider consent is obtained by the assessed organisation.
9. The controller and processor relationship for personal data is determined and recorded.
10. Cross-border implications are assessed.
11. Any sector notification obligation is discharged.
12. Deconfliction with any national or sector response body is agreed.
13. Classification and handling are agreed with the assessed organisation.
14. Ownership of the report, its distribution, and rights of onward disclosure are agreed in writing.
15. A mechanism for the resolution of disputes is agreed.

H2.3.2 Requirement 14 is routinely overlooked and routinely becomes contentious. It is settled before execution: who owns the report, who may see it, whether the mandating authority receives it, whether the assessed organisation may redact, and whether it may be provided to a regulator.

H2.4 Appointments across two organisations

Appointment	Located in	Function
Representative of the mandating authority	The tasking organisation	Ensures the assessment is conducted in accordance with the mandate. In direct contact with the assessed organisation's Trusted Agent.
Approving Authority of the assessed organisation	The assessed organisation	Accepts the operational risk to its systems. Signs the Letter of Authorisation.
Trusted Agent	The assessed organisation	Controls the engagement. Holds the authority to suspend.
Red Team Lead	The assessing organisation	As at Annex A
Approving Authority of the assessing organisation	The assessing organisation	Authorises its own personnel to undertake the work

H2.4.1 Two Approving Authorities exist and they authorise different matters. One authorises access to the systems; the other authorises the personnel to conduct the work.

H2.4.2 The authority to suspend rests with the assessed organisation's Trusted Agent. It rests neither with the assessing organisation nor with the mandating authority. The organisation bearing the operational consequence holds the authority to stop.

H2.5 Deconfliction between organisations

H2.5.1 The following apply in addition to Annex E, paragraph E.5.

- a. The deconfliction line is answered by the Red Team Lead throughout the execution period.
- b. The assessed organisation's Trusted Agent holds the number and the code word.
- c. The response period is shorter than for internal assessment. The default is fifteen minutes.
- d. The assessed organisation's route of escalation to any external body is recorded in the Rules of Engagement, and its Trusted Agent undertakes to deconflict before that route is used.
- e. Source addresses are provided to the Trusted Agent before execution.
- f. A procedure exists for the case in which the assessed organisation escalates externally before deconflicting.

H2.5.2 The Trusted Agent shall be briefed expressly that escalation to an external body without de-confliction causes the engagement to cease and may initiate a genuine incident procedure in another organisation.

H2.6 Variations in execution

Matter	Variation
Verification of scope	Every target is verified against the authorised space before contact. No institutional knowledge is available as a check.
Ambiguity	Ambiguity halts activity and is referred to the Trusted Agent. It is not resolved by the operator.
Data	The data belongs to the assessed organisation. Minimisation is a contractual obligation.
Storage of evidence	As required by the agreement, which may require storage within a particular jurisdiction
Personnel	Only personnel named in the Letter of Authorisation operate. Addition requires amendment of the letter.
Communication	All formal communication passes through the Trusted Agent, and never directly to the assessed organisation's technical staff.

H2.7 Variations in reporting

Matter	Variation
Ownership	As agreed. The default is that the assessed organisation owns the report and the mandating authority receives a summary.
Two reports	Frequently required: a full report for the assessed organisation and a summary for the mandating authority. The content of the summary is agreed before execution.
Comparison	Where several organisations are assessed under one mandate, organisations shall not be identifiable in comparative reporting unless the mandate expressly requires it. Comparison between organisations removes cooperation permanently.
Remediation	Tracked but not owned. The reporting cadence to the mandating authority is agreed.
Retest	Included in the agreement, with its own funding and schedule.

H2.8 Matters raised by the assessed organisation

H2.8.1 The following are anticipated and answered.

Question	Prepared answer
What qualifies the assessing team?	Credentials, the methodology, and the record of previous engagements
What follows if something is broken?	Cessation criteria, the position on liability, and the method of reversal
Who will see the report?	The agreed distribution, in writing
Will this be used against the organisation?	The purpose of the mandate and the non-punitive framing, in writing from the mandating authority
What data will be touched?	The rules on minimisation, prohibited proof, retention and destruction
Can the assessment be stopped?	Yes: unilaterally, at any time, without justification

Question	Prepared answer
What does the organisation receive?	Findings, detections, the retest, and its own activity record

H2.8.2 The final row is of greater consequence than it appears. An organisation that regards the engagement as extraction resists it. An organisation that regards it as a service cooperates. The activity record and the purple replay are what constitute the service.

PART H3 — EXERCISE

H3.1 Distinction from an engagement

H3.1.1 Exercise red teaming resembles an engagement and is not one.

	Engagement	Exercise
Purpose	Measure the defence and identify risk	Train the audience against stated learning objectives
Environment	Live systems	A range
Success	Objectives achieved, or the defence held	The audience learned
Adversary	Emulated for realism	Scripted for instruction
Pace	Weeks	Compressed to hours or days
Principal risk	Impact on production	Collapse of the exercise

H3.1.2 In an engagement the red team optimises for realism. In an exercise it optimises for the learning objectives. Where defeating the audience in the first hour prevents that audience practising the skill it attended to practise, the red team has failed, whatever the technical outcome.

H3.2 Team structure

H3.2.1 Exercises use a broader structure than engagements. The green and yellow functions are the most frequently omitted, and their absence is the ordinary reason an improvised exercise degenerates into maintenance of the range.

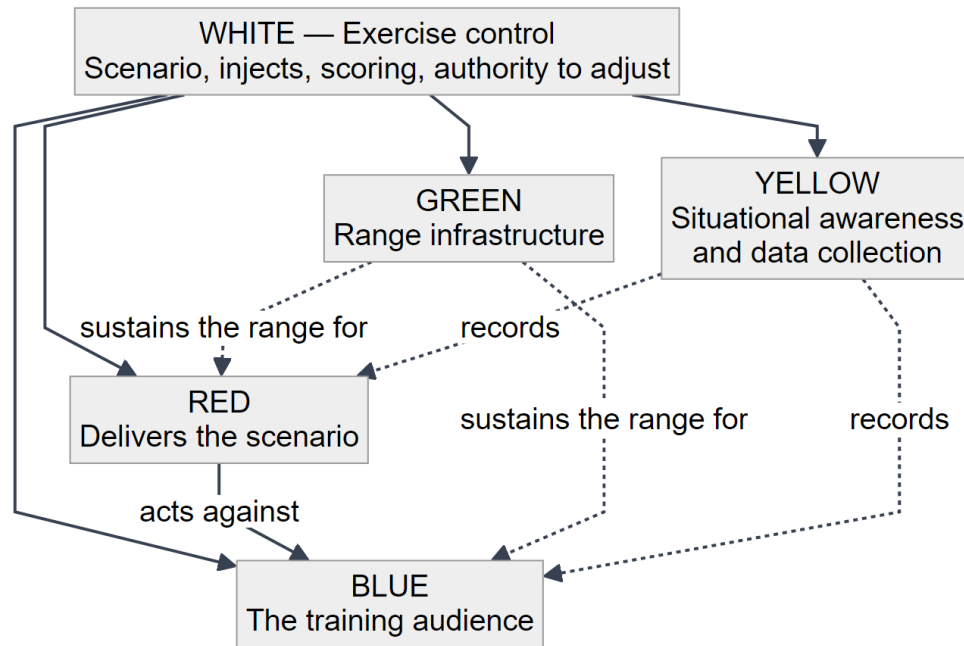


Figure H-2. Exercise team structure

H3.2.2 For any exercise larger than a single-day internal event, the green and yellow functions shall be staffed separately from red and white. Assigning them as a secondary duty guarantees that they are abandoned at the point they become necessary.

H3.2.3 Above six operators the red team is divided by attack surface: user-end device, application, and network, with additional groupings for control systems or identity where the scenario requires. Each has a lead. Below six operators the team is not divided.

H3.3 The command element

H3.3.1 Mature exercises train the command element and not only the operators, on the principle that in a real operation the constraint is ordinarily the speed and authority of decision rather than technical capability.

Level	Trains	Decisions
Political	Authority to act, thresholds for escalation, external communication	Whether to act; what may be disclosed
Strategic	Selection of objectives, allocation of resources, acceptance of risk	Which targets; what level of effect; when to stop
Tactical	Direction of operators, selection of technique, deconfliction	How the effect is achieved

H3.3.2 Operators report upward and receive direction downward on a realistic timeline, including realistic delay. The delay forms part of the training. An exercise in which operators act immediately does not exercise the command element.

H3.3.3 Legal advisers participate as players. In a real operation legal constraint arrives during the operation and not before it.

H3.4 Design

H3.4.1 Design proceeds from the learning objectives.

- State the learning objectives as observable behaviours.
- Determine what the audience must do to demonstrate each.

- c. Determine what the red team must present to create that opportunity.
- d. Design the attack path to deliver those presentations at the appropriate time.
- e. Construct the injects that guarantee the presentation occurs irrespective of red team progress.

H3.4.2 Step e distinguishes a designed exercise from an improvised one. Where a learning objective depends upon the audience observing a particular behaviour, that behaviour is guaranteed by inject and is not left to whether the red team reaches it.

H3.5 Pacing

Principle	Application
Early success	The audience must succeed at something within the first hours
Deliberate escalation	Difficulty rises on the exercise control team's schedule, not on the red team's opportunity
Capability in reserve	Full capability is not employed at the outset
No decisive result	Total compromise early ends the exercise and the instruction with it
Deliberate visibility	The red team is more detectable than a real adversary; the audience attends to practise detection
Provision for stall	Where the audience falls behind, the red team slows, repeats a technique more visibly, or the exercise control team injects

H3.6 Injects

Type	Purpose
Technical	Guarantee that a behaviour is presented
Informational	Simulate external input, such as intelligence reporting or a report from a partner
Pressure	Exercise decision-making, such as a media enquiry or a demand from command for an update
Escalation	Raise the stakes, such as effect upon a second service
Recovery	Permit the restore objective to be exercised

H3.7 Scoring and after-action review

H3.7.1 Scoring is against the learning objectives and not against red team achievement. The scoring model is published to the audience before the exercise. Behaviours are measured: detection, reporting, quality of decision, communication, containment. Scoring shall not permit the failure of an element to be attributed to an individual.

H3.7.2 The after-action review is the product of the exercise.

Stage	Timing	Content
Immediate review	Same day	First impressions, while recollection is current
Red team disclosure	Same or following day	The red team presents its full attack path with times
Reconciliation	Following day	Red actions against blue observations, step by step
Formal review	Within two weeks	Against the learning objectives, with actions

H3.7.3 The red team disclosure is the session of greatest value. The audience observes what was occurring while it was inferring. It is prepared with a timeline, a diagram, and the answer to what would have detected each step.

H3.8 Internally conducted exercises

H3.8.1 The minimum viable internal exercise comprises: one day; two operators; one white team member holding the scenario, injects and the authority to stop; one green team member who is not a red team member; one yellow team member or automated collection with a named reviewer; the defensive element working from a range replica; not more than three learning objectives; five to eight pre-written injects; and a two-hour review the same day.

H3.8.2 An exercise shall not be conducted against production systems. An exercise compresses time, escalates by script, and deliberately provokes response. That combination against live systems produces an incident.

H3.9 Participation in external exercises

Matter	Requirement
Rules	The exercise director's rules supersede these. They are read; they differ.
Records	The recording and conduct standards of this methodology continue to apply to the team's own activity
Classification	Exercise material is ordinarily restricted. What may be retained is confirmed.
Capture of learning	An appointment is designated to record techniques, tooling and lessons. This is the principal return on the investment.
Follow-up	Lessons are processed on pro forma T11 and the annexes and scenario library amended

H3.9.1 Participation is treated as a training investment carrying a required deliverable, being a written lessons pack, and not as attendance at an event.

PART H4 — PURPLE TEAM

H4.1 Basis for precedence

H4.1.1 Purple team activity is the category with which a new capability commences.

Basis	
Product	A two-day exercise produces deployed detections. A covert engagement produces a report after eight weeks.
Risk	The defensive element is informed. Deconfliction is trivial. Nothing is mistaken for a genuine attack.
Relationship	The defensive element experiences the red team as a resource. Every subsequent covert engagement depends upon that.
Self-assessment	Deficiencies in the red team's own tooling, records and tradecraft are exposed without an audience.
Effect	Coverage increases measurably.

H4.2 Operating models

Model	Description	Adopted
Exercise	Scheduled collaborative sessions	At the outset
Operationalised	Continuous, partly automated validation as a virtual team	Once a technique library exists and detections are stable
Dedicated	A permanently staffed function	Larger organisations only

H4.3 Appointments

Appointment	Function
Exercise lead	Conducts the day, maintains pace, records results
Operator	Executes the technique and explains its effect
Analyst	Searches telemetry in real time
Detection engineer	Constructs and deploys the rule during the exercise
Threat intelligence	Selects techniques and provides adversary context
Recorder	Records results as they occur

H4.3.1 All are present in the same location, or on the same call, at the same time.

H4.4 Conduct

H4.4.1 The following sequence is followed for each technique.

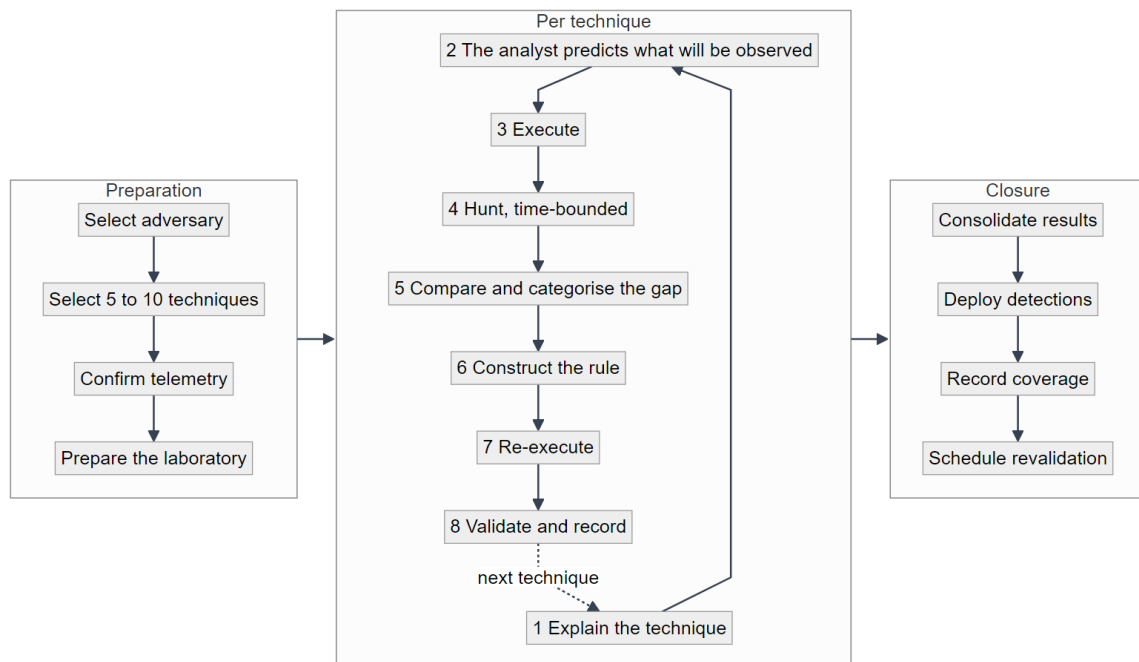


Figure H-3. Purple team sequence

H4.4.2 Step 2 shall not be omitted. The difference between what the defensive element expects to observe and what it observes is the instructive part of the exercise.

H4.4.3 Steps 6 to 8 are what constitute a purple team exercise rather than a demonstration. An exercise concluding at step 5 has produced a list of gaps.

H4.5 Record of results

H4.5.1 The recorder maintains the following during the exercise. It is the product.

Technique	Procedure	Predicted	Telemetry existed	Found by hunt	Alert existed	Gap category	Rule constructed	Validated
-----------	-----------	-----------	----------------------	---------------	---------------	--------------	---------------------	-----------

H4.5.2 Gap categories are those at Annex F, paragraph F1.3.2.

H4.6 Planning

Matter	Standard
Frequency	Monthly. Consistency is of greater value than scale.
Duration	One to two days
Techniques	Five to ten. Fewer is not worth the coordination; more degrades quality.
Selection	From a threat profile. One tactic per exercise is effective.
Preparation	Every technique tested in the laboratory beforehand
Environment	Production, or an environment representative of it. A laboratory that does not correspond to production measures the laboratory.
Authorisation	Standing Rules of Engagement for purple team activity, with a scope note per exercise. The Letter of Authorisation remains required.
Product	Results table, deployed detections, updated coverage, technique list for the next exercise

H4.7 Annual sequence

H4.7.1 The following sequence is recommended for the first year.

Month	Tactic	Basis
1	Execution	Foundational; establishes whether endpoint telemetry exists
2	Persistence	High detection value, low risk, straightforward to reverse
3	Credential Access	The tactic of highest value in most estates
4	Discovery	Inexpensive to detect and frequently missed entirely
5	Lateral Movement	The tactic in which most estates have least visibility
6	Stealth and Defense Impairment	Establishes whether existing detections survive contact, and whether interference with them is noticed
7	Command and Control	Validates network telemetry
8	Collection and Exfiltration	Connects to data protection concerns
9	Privilege Escalation	
10	Initial Access	Including social engineering
11	Impact	Destructive behaviours, emulated safely
12	Revalidation	Re-run months 1 to 4 and confirm the detections still operate

H4.7.2 Month 12 is of greater consequence than it appears. Detections decay through platform change, tuning and migration. A detection never revalidated is an assumption.

H4.8 Purple replay

H4.8.1 The purple team exercise of greatest value is the one following a covert engagement, conducted at phase 7.

- a. Take the techniques that were not detected during the engagement.
- b. Re-run them openly with detection engineering.

- c. Construct detections against the procedure used, and not against a general description of the technique.
- d. Validate.
- e. Record in the lessons for the engagement.

H4.8.2 Purple replay closes the interval between identifying a gap and correcting it. It is budgeted as part of every engagement. An engagement without it is half delivered.

H4.9 Limitations

H4.9.1 The following are stated in every purple team report, because they are routinely overstated.

- a. Purple team activity does not establish whether the defensive element detects an unannounced attack. The element knew what would occur and when.
- b. It does not assess response. Nothing was contained, escalated, or acted upon out of hours.
- c. It does not assess the full attack sequence. Techniques were executed in isolation or in short chains, with the environment cooperating.
- d. It does not assess decision-making. No person was required to decide whether to disconnect a production service.

H4.9.2 Purple team activity produces detections. Red team engagements establish whether the system as a whole functions. Both are required, and purple team activity comes first. A programme conducting only purple team activity will hold well-constructed detection rules and no knowledge of whether they are acted upon.

ANNEX I — SPECIALISED ENVIRONMENTS

Supporting Chapter 4, paragraph 4.9, of the Red Team Methodology. Issued under the authority of the Head of Red Team.

This annex applies where an engagement touches a classified or air-gapped network, a mission, command or weapon system, a deployed or tactical network, installation operational technology, or an allied or coalition system. Each is capable of converting a routine engagement into a serious incident. None shall be entered without the controls in this annex.

I.1 Applicability

I.1.1 The following check is conducted at phase 0. Where any item applies, this annex applies and the corresponding paragraph is mandatory.

	Does the scope include	Paragraph
1	A network holding material classified above the working level of the red team	I.2
2	An air-gapped or physically separated network	I.3
3	A mission, command or weapon system	I.4
4	A deployed, tactical or expeditionary network	I.5
5	Installation operational technology: power, water, fuel, environmental control, access control	I.6
6	A system owned by, or holding information belonging to, another nation or an alliance	I.7
7	A system supporting a unit at readiness, on operations, or under certification	I.8

I.2 Classified environments

I.2.1 The governing constraint

I.2.1.1 In a classified environment the constraint is rarely technical. The engagement's own artefacts, being the Rules of Engagement, the plan, the records, the evidence and the report, take the classification of the environment they describe, at the time they are created.

I.2.1.2 This is planned for before execution. A team generating classified evidence on an unaccredited system has created a security incident that will outrank every finding in the report.

I.2.2 Controls

	Control
1	Every operator holds clearance at or above the classification of the environment, verified before phase 3 and not inferred from appointment
2	Operator systems used in the environment are accredited for that classification. General-purpose team systems shall not be used.
3	The evidence repository is accredited to the same level. Evidence does not leave the accredited boundary.
4	Tooling is reviewed and approved under the applicable accreditation process before phase 3
5	The report is produced, held and distributed within the classified environment. A summary at lower classification may be produced only if formally derived and assessed for aggregation.
6	The cleared list is drawn from clearance and from need to know. Clearance alone does not confer access.
7	Every deliverable is reviewed for classification by the security authority before release
8	A suspected spill is reported immediately under the organisation's procedure, before any engagement consideration, and the engagement ceases

I.2.3 Aggregation

I.2.3.1 Findings that are individually unclassified may aggregate to a classified picture. A complete account of an estate's weaknesses is more sensitive than any single weakness within it.

I.2.3.2 Every report against a classified environment shall be assessed for aggregation before classification is assigned, by the security authority and not by the red team. The report is assumed to classify above its individual components.

I.3 Air-gapped and physically separated networks

Matter	Requirement
Command and control	The tiered infrastructure at Annex D does not apply. Operations are conducted from within, with local recording.
Movement of evidence	Conducted through a controlled cross-domain process, agreed and approved at phase 1. It shall not be improvised at culmination.
Removable media	Any media used is accounted for, recorded, and disposed of under the applicable regulation. This is ordinarily the highest-risk element of the engagement.

Matter	Requirement
Introduction of tooling	Tools are introduced through the accredited process. Introduction of unapproved code into an air-gapped network is a serious incident irrespective of intent.
Realistic vector	The realistic vector into such a network is removable media, the supply chain, or an insider. The emulation reflects that and not what is convenient.
Deconfliction	Network telemetry is not available. A physical or out-of-band procedure is agreed, with a defined interval for contact.
Cleanup	Nothing can be removed remotely afterwards. The cleanup register is verified before operators leave the facility.

I.4 Mission, command and weapon systems

These systems are outside scope by default. They are brought into scope only with a documented safety case, the written consent of the system authority, and a risk acceptance by the Approving Authority naming the system.

I.4.1 Basis of the default exclusion

- Availability is a matter of readiness and potentially of safety.
- Many are certified or accredited configurations, and unplanned change may invalidate that certification.
- Failure modes under unexpected input are frequently undocumented.
- The consequence of degradation is not measurable in the terms this methodology otherwise uses.

I.4.2 Where a system is brought into scope

	Requirement
1	Written consent of the system or design authority, and not of the operating unit alone
2	A representative test environment exists, and every technique is proven there first
3	A safety case covering each authorised technique, reviewed by the safety authority
4	Engineering staff able to intervene physically are present and briefed throughout
5	The system is in a known-safe, non-operational state, confirmed at the start of each session
6	The unit is not at readiness for the duration
7	Any anomaly in the behaviour of the system causes activity to cease, irrespective of cause
8	The effect upon certification and accreditation is assessed and accepted in advance

I.4.3 The boundary

I.4.3.1 For most objectives, demonstrating that a mission system is reachable from the general-purpose network constitutes the finding. Entry adds substantial risk and little information.

I.4.3.2 The default course is to stop at the boundary, demonstrate reachability, and report it. The boundary is crossed only where the objective cannot otherwise be met and the conditions at paragraph I.4.2 are satisfied.

I.5 Deployed and tactical networks

Matter	Requirement
Live operations	Engagements against a network supporting a live operational task are prohibited
Window	Work-up, in barracks, or after recovery
Consent	The commander of the deployed unit consents and is the Trusted Agent, or nominates one
Bandwidth	Engagement infrastructure shall not consume operationally significant bandwidth. Traffic is modelled before execution.
Vector	Tactical networks face different vectors: physical capture, radio frequency, supply chain, local insider. Those are emulated.
Communications	Deconfliction operates over the communications available at the pace those permit. The response period is set accordingly and tested.
Cleanup	Verified before the unit deploys. An artefact remaining on a system that then deploys cannot be recovered.

I.6 Installation operational technology

I.6.1 Applies to power, water, fuel, environmental control, physical access control, fire and life-safety systems.

I.6.2 The safety provisions at Annex G, paragraph G.5.2, apply, with the following additions.

	Addition
1	Life-safety and fire systems are permanently outside scope. No safety case will be accepted.
2	Physical access control may be assessed, but never in a manner capable of causing a facility to fail secure or fail open. The failure mode is modelled before any action.
3	The installation commander is informed, and guard force leadership is briefed that authorised activity is occurring
4	For fuel, power and water: demonstrate reachability from the general-purpose network and stop. The reachability is the finding.
5	Engagements are scheduled outside periods of heightened alert state

I.7 Allied and coalition systems

	Requirement
1	National authority alone is not sufficient. Systems owned by, or holding information belonging to, another nation or an alliance require that owner's authorisation.
2	The information owner is determined, and is frequently not the system operator
3	The applicable agreement, memorandum or technical arrangement is reviewed by the legal adviser before phase 1 completes

	Requirement
4	Releasability of findings is agreed in writing before execution: who receives the report, in what form, and whether findings are releasable to the alliance or bilaterally
5	Classification and caveats are applied under the owning nation's or alliance's rules and not only under the assessing organisation's
6	Where a partner's response element monitors the systems, it is included in the deconfliction arrangement

I.7.1 Where authority is unclear the engagement does not proceed. Ambiguous authority over an allied system is not a risk proportionate to an assurance activity.

I.8 Readiness and operational tempo

I.8.1 Red team activity shall not degrade readiness. This is a constraint and not a scheduling preference.

	Requirement
1	No engagement against systems supporting a unit at readiness, on operations, or under certification
2	The engagement calendar is deconflicted against the operational and exercise programme at phase 0
3	The Trusted Agent holds standing authority to terminate on a change in alert state or operational tasking, without discussion and without notice
4	Termination for operational reasons is not a failure of the engagement. It is recorded, what was gathered is preserved, and the engagement is rescheduled.
5	Where an engagement is terminated for operational reasons, cleanup is completed immediately and not deferred

I.9 Additional cessation criteria

I.9.1 In addition to those at Chapter 8, paragraph 8.15.

- a. A change in alert state or readiness posture.
- b. Receipt by a supported unit of an operational tasking.
- c. A suspected classification spill or breach of handling.
- d. Any anomaly in a mission, command, weapon or operational technology system, whether or not attributed to the red team.
- e. Contact with an allied or coalition system not covered by the authorisation.
- f. Loss of accountability for any removable media used during the engagement.
- g. Any indication that engagement activity has been observed by, or attributed to, an external party.

I.10 Additional requirements at phase 1

I.10.1 Added to gate G1 at Annex C, paragraph C.5.3, where this annex applies.

1. The applicability check at paragraph I.1 is completed and recorded.
2. Clearances are verified against the classification of the environment.

3. Operator systems and the evidence repository are accredited to the required level.
4. Tooling is approved under the applicable accreditation process.
5. The cross-domain process for movement of evidence is agreed and approved.
6. Aggregation and classification of deliverables are assessed by the security authority.
7. For a mission or weapon system: consent of the system authority, the safety case, and the test environment are confirmed.
8. For an allied or coalition system: the owner's authorisation and the releasability of findings are agreed in writing.
9. The engagement calendar is deconflicted against the operational and exercise programme.
10. The Trusted Agent's standing authority to terminate on a change of alert state is confirmed.

ANNEX J — CAPABILITY: TOOLING, LABORATORY AND TRAINING

Supporting Chapters 6 and 10 of the Red Team Methodology. Issued under the authority of the Head of Red Team.

This is the annex most subject to change. It is reviewed annually and whenever the estate or the toolset changes.

Part J1 covers tooling and the laboratory. Part J2 covers skills and training.

PART J1 — TOOLING AND LABORATORY

J1.1 Principles

	Principle
1	A tool is not used against a target until its artefacts, network signature and failure modes are understood
2	A tool is not used against a target until it has been exercised in a laboratory environment representative of that target
3	Native and signed system tooling is preferred where the objective and capability level permit
4	Tools are obtained from authoritative sources and their integrity verified. Offensive tooling is itself a target for supply-chain compromise.
5	Every tool in the baseline is recorded, versioned and owned
6	Offensive tooling is not held on personal devices
7	Capability is developed only where it cannot be obtained. Custom development is addressed at paragraph J1.8.

J1.2 The laboratory

J1.2.1 The laboratory is the precondition for the standing instruction at paragraph 8.6 of the methodology and is established before the first engagement.

Component	Purpose	Minimum
Directory environment	Assessment of identity techniques against the production directory model	One controller, two members, representative policy and organisational structure

Component	Purpose	Minimum
Endpoint build	Assessment of techniques against the production image and endpoint protection configuration	The production image
Server build	Assessment of server-side techniques	Representative of production roles
Telemetry replica	Establishing what telemetry a technique produces	The same agents and forwarding configuration as production
Cloud tenancy	Assessment of control-plane techniques	A separate tenancy, never production
Network segment	Isolation	No route to production
Snapshot capability	Reset between tests	Any hypervisor

J1.2.2 The telemetry replica is the component most frequently omitted and the component of greatest value. Without it the question of what a technique produces in the organisation's own telemetry cannot be answered, and every purple team exercise and detection recommendation depends upon that answer.

J1.3 Categories of tooling

Category	Selection criteria
Command and control	Actively maintained; encrypted transport; support for redirectors; comprehensive automatic recording; controllable traffic profile
Reconnaissance	Passive by default; rate-limitable
Enumeration	Rate-limitable; predictable behaviour against fragile targets
Identity and directory	Read-only by default; understands the directory model in use
Credential recovery	Understood artefacts; deterministic behaviour
Lateral movement	Multiple protocol options
Cloud and hosted services	Provider-specific; read-only by default
Application	Standard proxy tooling
Social engineering	Per-recipient tracking; rate limiting; reliable exclusion of listed individuals
Payload construction	Understood output; testable against the production endpoint protection configuration
Physical	Only where authorised, and never without separate authorisation
Reporting	Encrypted; access-controlled; audited

J1.4 Selection of a command and control framework

J1.4.1 This is the most consequential tooling decision. Candidates are assessed against the following.

	Criterion	Basis
1	Comprehensive automatic recording	Where an operation cannot be reconstructed from the framework's own records, the framework is unsuitable for authorised work
2	Encrypted transport	Required by paragraph 8.13 of the methodology
3	Support for redirectors	Required by the tiered structure at Annex D
4	Controllable traffic profile	To correspond with the emulated adversary
5	Multiple operators, with actions attributable	Required for the operator record

	Criterion	Basis
6	Active maintenance	Abandoned frameworks become both detectable and unsupported
7	Lawful provenance and licensing	
8	Familiarity within the team	A framework that is only partly understood is a liability under pressure

J1.4.2 Criteria 1 and 8 outrank capability. A well-understood and comprehensively recorded framework is preferable to a more capable one that is partly understood.

J1.5 Approval of a tool

J1.5.1 The following sequence applies before a tool enters the baseline.

- a. The operator proposes the tool, its purpose and its source.
- b. Provenance is verified: an authoritative source, integrity checked, licensing confirmed.
- c. The tool is examined for undocumented behaviour, including whether it contacts any third party.
- d. The tool is exercised in the laboratory, and its artefacts, network signature and failure modes are recorded.
- e. The tool is exercised against the production endpoint protection configuration to establish the expected detection.
- f. The Red Team Lead approves the tool and records it in the inventory with its version.

J1.5.2 Sub-paragraph c is not discretionary. Offensive tooling obtained from unverified sources has been found to transmit operator data to third parties. Execution of such a tool within an assessed environment constitutes a compromise caused by the red team.

J1.6 Inventory

J1.6.1 The inventory records, for each tool: name, version, category, source, verification of integrity, laboratory testing, documentation of artefacts, the approving appointment, the date, and the owner.

J1.7 Record of artefacts

J1.7.1 A record is maintained for each tool, populated from laboratory testing. It permits an operator to assess risk and a detection engineer to construct a rule.

Field	Content
Tool and version	
Function	
Files written	Paths, names, and whether removed on exit
Configuration changes	
Processes created	Names, parents, command lines
Network signature	Protocols, ports, patterns, certificate characteristics
Records generated	Which logs, which identifiers
Detection by the production configuration	Prevented, alerted, telemetry only, or not observed
Failure modes	What fails, and what it affects
Cleanup required	What must be removed

J1.8 Custom capability

	Requirement
1	Custom development is not undertaken where an established tool performs the function adequately
2	It is justified only where the threat profile requires a capability that nothing available provides
3	Custom tooling is version-controlled, reviewed by a second person, and documented to the standard at paragraph J1.7
4	Custom tooling records to the same standard as established frameworks
5	Custom tooling is not distributed outside the team
6	Custom command and control or implant development is not undertaken before the process domain has reached maturity level 2. See Annex F, paragraph F2.5.7.

J1.8.1 Requirement 6 exists because implant development is the most engaging work available to a red team and, at low maturity, the least productive.

J1.9 Operator systems

- a. Dedicated and controlled. Never personal devices.
 - b. Full disk encryption.
 - c. Automatic session capture enabled and verified before every engagement.
 - d. Synchronised to Coordinated Universal Time.
 - e. No standing access to production systems.
 - f. Engagement data held in the controlled repository and not on local storage.
 - g. Rebuilt between engagements where classification requires it.
 - h. Inventoried, with a named owner.
-

J1.10 Annual review

J1.10.1 The Head of Red Team reviews the following annually.

1. Whether every tool in the baseline remains maintained.
2. Whether any has been superseded.
3. Whether the artefact records remain accurate against the current production endpoint configuration.
4. Whether any tool now triggers detections that change how it should be used.
5. Whether licensing remains current and lawful.
6. Whether the laboratory still represents production.
7. Whether the threat landscape has created a capability gap.

J1.10.2 Item 3 is material. An artefact record produced against a superseded endpoint configuration describes a system that no longer exists.

PART J2 — SKILLS AND TRAINING

J2.1 Priority of skills

J2.1.1 The following are ranked by the frequency with which their absence constrains a red team. The ordering differs from that implied by most training paths.

	Skill	Basis for the position
1	Written expression	The report is the product. A team that finds everything and writes poorly delivers nothing. This is consistently the largest gap in technically strong teams.
2	Identity and directory services	The route of most modern attack paths
3	Operating system internals	Enables assessment of risk and construction of detection recommendations
4	Networking	Underpins movement and infrastructure
5	Detection and telemetry	A detection cannot be recommended that the recommender could not construct
6	Cloud and hosted services	Increasingly where the attack path runs, and frequently outside the visibility of the defensive element
7	Scripting	Adaptation of tooling; automation of evidence collection
8	Threat intelligence analysis	Conversion of reporting into an emulation plan
9	Applications	Where initial access or the objective frequently sits
10	Social engineering	High value, high legal sensitivity
11	Physical	Only where in scope. Highest personal risk.

J2.1.2 Written expression is placed first because its absence most reliably destroys the value of everything else, and because it is the skill for which time is least often allocated.

J2.2 Skills matrix

J2.2.1 Maintained by the Head of Red Team and reviewed twice yearly. Levels: 0 none; 1 aware; 2 able with support; 3 independent; 4 able to instruct.

Skill	Minimum required
Written expression	3 for the Red Team Lead; 2 for all
Identity and directory	3 for one; 2 for all
Windows internals	3 for one; 2 for all
Linux internals	2 for one
Networking	2 for all
Detection and telemetry	3 for one
Cloud and hosted services	2 for one
Scripting	2 for all
Threat intelligence	2 for one
Command and control operation	3 for all
Infrastructure construction	3 for one
Applications	2 for one
Social engineering	2 for one
Evidence and recording discipline	3 for all
Rules of Engagement and legal awareness	3 for all

J2.2.2 The final two rows require level 3 of every member. Neither is technical. Both are what keep the capability lawful and safe, and neither may be delegated to whichever member is competent at it.

J2.2.3 No capability shall rest with a single individual. See Annex A, paragraph A.5.4.

J2.3 Development

J2.3.1 First ninety days

Period	Activity	Outcome
Week 1	Read the methodology and annexes. Sign the acknowledgement of conduct.	The rules are known
Weeks 1 to 2	Construct and reconstruct the laboratory	An environment is owned
Weeks 2 to 4	Attend a purple team exercise as recorder	The full cycle is observed
Weeks 3 to 6	Exercise five techniques in the laboratory and document their artefacts to the standard at paragraph J1.7	First contribution
Weeks 5 to 8	Operate in a purple team exercise under supervision	Supervised execution
Weeks 8 to 10	Write a section of a report and have it reviewed	The most instructive activity of the period
Weeks 10 to 12	Operate in an engagement under supervision	Supervised engagement

J2.3.1.1 No operator works unsupervised in an assessed environment within ninety days of joining. Prior experience elsewhere does not vary this. The constraint is knowledge of this methodology and of this estate, not technical skill.

J2.3.2 Continuing

Frequency	Activity
Weekly	Four hours of protected laboratory and research time per operator
Monthly	A purple team exercise
Monthly	One technique studied in depth and documented to the artefact standard
Quarterly	One external competition or exercise
Twice yearly	Review of the skills matrix and of individual development plans
Annually	One formal course per operator
Annually	One external exercise

J2.3.2.1 Twenty per cent of establishment time is reserved for development, per Annex A, paragraph A.5.4.

J2.4 Sources of training

J2.4.1 Freely available

Resource	Value
MITRE ATT&CK	The common language. The foundation.
Centre for Threat-Informed Defense emulation library and micro-emulation plans	Ready-made plans, and the model for the organisation's own

Resource	Value
Purple Team Exercise Framework	The operating model at Annex H, part H4
Atomic Red Team	Per-technique tests, suited to constructing a micro-plan library
Vendor threat reporting	The raw material for threat profiles
Published incident accounts and advisories	Documented adversary behaviour
The laboratory	The environment of greatest value available

J2.4.2 Formal training and certification

J2.4.2.1 Certification is a target within the skills matrix and a signal of credibility for external engagements. It is not a precondition for contribution.

J2.4.2.2 Where resources are constrained, expenditure is prioritised in the following order.

- The laboratory: infrastructure and licences.
- Instruction in identity and directory services for the most capable operator.
- Participation in an external exercise.
- Certification.

J2.5 Retention of knowledge

J2.5.1 Capability held only by individuals departs with them. The following are maintained.

Artefact	Owner	Content
Records of tool artefacts	The operator who tested the tool	Per paragraph J1.7
Technique library	The team	Per technique: procedure, artefacts, telemetry produced, detection guidance
Micro-emulation plans	The team	Re-runnable chains of three to five techniques
Scenario library	The Head of Red Team	Reusable scenarios mapped to threat profiles
Threat profile library	The Threat Intelligence Analyst	Reusable profiles, refreshed annually
Lessons	The Head of Red Team	Per engagement, on pro forma T11
Environment knowledge	The team	What is known of the estate, refreshed at each engagement

J2.5.2 A library of ten re-runnable micro-emulation plans is of greater value to a team of this establishment than a custom implant, and is the asset that renders the departure of an operator survivable.

J2.6 Rotation and fatigue

Risk	Mitigation
Narrowing of skill	Operators rotate across focus areas between engagements
Fatigue during extended engagements	Breaks enforced; no high-risk action when tired, per Annex E paragraph E.9

Risk	Mitigation
Isolation from the defensive element	Purple team exercises; rotation of operators through the defensive element
Loss of purpose	Defensive improvements attributable to the capability are recorded and reported, per Annex F paragraph F2.4
Single points of knowledge	Every capability documented; no undocumented dependency upon one individual

ANNEX K — BASIS, APPLICABILITY AND SOURCES

Issued under the authority of the Head of Red Team.

This annex records the derivation of the methodology, the limits on importing requirements from external frameworks, and the authoritative sources used. It exists so that each control can be defended by its purpose and provenance rather than by preference or custom.

The source baseline was reviewed on 3 August 2026. A source being listed does not by itself make it legally binding on an engagement.

K.1 Applicability and hierarchy

K.1.1 Applicability is determined for the organisation, jurisdiction, sector and engagement under Annex G. Financial-sector frameworks are used as mature reference models outside their legal scope; they shall not be represented as mandatory where they are not.

Source family	Status in this methodology	Use
Applicable law, regulation, contract, mandate and provider terms	Binding when applicable	Legal authority, privacy, sector obligations, system and provider permission
TIBER-EU 2025	Voluntary, entity- and sector-agnostic framework unless adopted by an authority; also operational guidance for DORA TLPT	Control Team, threat-led lifecycle, production-risk governance, purple teaming and remediation
DORA and its delegated TLPT rules	Binding for financial entities and tests within their legal scope; reference model otherwise	Regulatory applicability, internal-tester safeguards, formal deliverables and mutual recognition
CBEST 2024	Supervisory framework for participating United Kingdom financial institutions; reference model otherwise	Golden thread, operational risk assessment, third-party scope, detection and response, read-across
G7 Fundamental Elements for TLPT	Non-binding financial-sector policy baseline	Proportionality, stakeholder responsibilities, provider assurance, closure and anonymised thematic learning
NIST Special Publications	Authoritative guidance, not law unless adopted by an authority or contract	Test lifecycle, assessment planning, measurement quality, incident response and evidence handling
CREST CTI, TISA and TLPT standards	Accreditation and competence benchmark	Provider and personnel capability, assurance and management expectations

Source family	Status in this methodology	Use
MITRE ATT&CK and Attack Flow	Open knowledge base and data model	Versioned behaviour vocabulary, traceability and attack-path representation
NCSC, CISA and OWASP guidance	Authoritative implementation guidance	Exercise design, outcome measures, red team safeguards and technical test coverage
ISO/IEC 27037	International evidence-handling guidance	Identification, collection, acquisition and preservation where evidential handling is required
Practitioner and exercise publications	Non-normative supporting material	Usability, tradecraft and exercise design, subject to verification against authoritative sources

K.1.2 Where sources conflict, the order of precedence is:

1. applicable law and lawful direction;
2. regulator or competent-authority requirements;
3. contract, mandate, classification policy and provider terms;
4. the signed Rules of Engagement and Letter of Authorisation;
5. this methodology and its annexes;
6. external guidance and practitioner material.

K.1.3 A lower item cannot enlarge authority granted by a higher item. The most restrictive applicable condition governs unless the body entitled to change it does so lawfully and in writing.

K.1.4 Edition, jurisdiction and review date matter. References to ATT&CK, cloud-provider policies, regulatory technical standards and operational guidance are versioned in the engagement plan. A web page without a recorded access date is not adequate evidence of a provider permission.

K.2 Controls derived from authoritative frameworks

K.2.1 TIBER-EU 2025

K.2.1.1 TIBER-EU is the European framework for controlled, intelligence-led red team testing of critical or important functions and the live production systems, people, processes and technologies supporting them. Although developed in a financial-sector context, the 2025 framework expressly permits use by entities of any type or size across financial and other sectors. It uses **Control Team** and **Control Team Lead**. The former term **White Team** is retained only when citing an older edition or an external framework that still uses it.

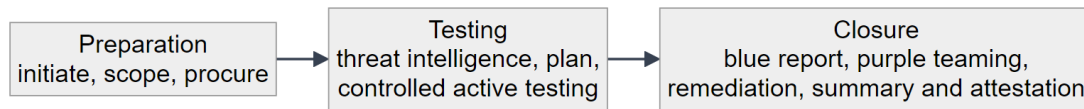


Figure K-1. TIBER-EU 2025 lifecycle

K.2.1.2 The framework separates the entity's Control Team and Control Team Lead, the Blue Team, threat intelligence and red team providers, and the authority's TIBER Cyber Team and Test Manager. The entity retains end-to-end ownership and risk accountability.

K.2.1.3 The following controls are adapted here:

- a. scope begins with critical or important functions and follows their supporting systems, people, processes and third parties;
- b. scenarios follow targeted threat intelligence and maintain a traceable path from threat evidence to objective, scenario, action and measure;
- c. testing of live production is governed as operational risk, with explicit safety, deconfliction, cessation, restoration and escalation controls;
- d. the defensive element reports what it observed before full disclosure;
- e. purple teaming is planned as a closure activity, not left to chance;
- f. remediation, retest and senior ownership complete the lifecycle; and
- g. formal deliverables and attestation are produced only where the applicable scheme requires them.

K.2.1.4 TIBER's active-testing duration and provider model are regime-specific and are not universal minimums for this internal capability. Its internal-tester safeguards are, however, a strong benchmark for high-assurance work: a qualified lead, at least two additional testers, recent organisational knowledge, continuing training, backups, conflict controls and external challenge. Annex A scales those controls for a small team.

K.2.2 DORA threat-led penetration testing

K.2.2.1 Regulation (EU) 2022/2554 and Delegated Regulation (EU) 2025/1190 govern threat-led penetration testing for financial entities within their scope. Applicability, frequency, competent-authority direction and formal deliverables are legal determinations, not assumptions made by the red team.

K.2.2.2 For internal testers, the delegated regulation establishes safeguards concerning policy, capability and resources, organisational placement and conflicts, and requires a test manager supported by at least two additional testers. It also addresses knowledge of the entity and training. DORA also requires external testers every three tests when internal testers are used, and requires some institutions to use only external testers. These exact requirements are applied where DORA applies and are otherwise treated as a maturity benchmark, not copied as law.

K.2.2.3 This methodology does not claim DORA certification, mutual recognition or regulatory attestation. A formal TIBER or DORA engagement uses the competent authority's current forms and process in addition to this methodology.

K.2.3 G7 Fundamental Elements for TLPT

K.2.3.1 The G7 Cyber Expert Group provides a non-binding baseline for authorities, financial entities and providers. It treats TLPT as one component of a wider assessment toolkit and requires proportionality to entity importance, size, complexity, sophistication and risk.

K.2.3.2 Its six elements are scoping and risk management; resourcing; threat intelligence; penetration testing; closure and remediation; and anonymised thematic data. This methodology adapts the first five directly. Thematic reporting is used only where authority, classification, confidentiality and data-protection controls prevent identification of an engagement, entity or individual.

K.2.4 CBEST 2024

K.2.4.1 CBEST organises an assessment into initiation, threat intelligence, penetration testing, and closure. Its principal contribution is the **golden thread**: critical business services lead to threat scenarios, target systems, red team actions, defensive observations, findings and remediation.

K.2.4.2 The following are adopted:

- the test is itself managed as an operational risk;
- threat intelligence is independently challenged;
- material third parties and concentration dependencies are considered in scope design;
- the defensive element conducts a detection-and-response assessment;
- remediation includes read-across to comparable services and systems; and
- closure demonstrates not merely that a task was completed, but that the risk reduction was verified.

K.2.5 NIST guidance

K.2.5.1 NIST SP 800-115 establishes testing as a managed process of planning, discovery, attack and reporting. Planning contains no target interaction. Discovery and attack may iterate, but only inside the approved boundary.



Figure K-2. NIST SP 800-115 assessment process

K.2.5.2 NIST SP 800-55 Volumes 1 and 2 support Annex F: every measure has a decision purpose, definition, source, owner, collection and analysis method, validation, limitations and review cycle. Data quality, uncertainty, sample size and comparability are reported.

K.2.5.3 NIST SP 800-61 Revision 3 and SP 800-53 Revision 5 support integration with incident response, assessment controls and governance. Red team activity never displaces the incident-response authority during a suspected genuine event.

K.2.5.4 NIST SP 800-86 supports the proportionate preservation controls in Annex E. A routine assurance record is not called forensic evidence unless the required handling and provenance have been maintained.

K.2.6 MITRE ATT&CK and Attack Flow

K.2.6.1 ATT&CK is the common behaviour vocabulary; it is not a test plan, a severity model, proof of threat relevance or a denominator that must be exhausted.

K.2.6.2 Every profile, plan and report records the ATT&CK release used. At the date of this publication the current major release is ATT&CK v19, published 28 April 2026. That release changed the Enterprise tactic model, including separating behaviours formerly grouped under Defense Evasion into Stealth and Defense Impairment. Historical results retain their original mapping and are not silently remapped.

K.2.6.3 MITRE adversary-emulation plans and Center for Threat-Informed Defense resources may inform procedures, but current threat evidence and the local environment determine selection. A micro-emulation is a short, risk-controlled chain chosen for one decision, not a reduced claim of full actor emulation.

K.2.6.4 Attack Flow 4.0 may be used where branching, dependencies and control outcomes cannot be represented clearly in a linear ATT&CK list. Flow identifiers connect the threat profile, plan, operator record, evidence and report.

K.2.7 CREST

K.2.7.1 CREST competence and accreditation material is used as a benchmark for threat intelligence, assurance, technical delivery and red team management. It does not confer legal authority and does not replace assessment of an individual's relevant experience.

K.2.7.2 In 2026 CREST introduced Cyber Threat Intelligence (CTI), Threat Intelligence for Simulated Attack (TISA) and Threat-Led Penetration Testing (TLPT) accreditation terminology. References to older STAR terminology are historical unless the commissioning scheme expressly retains it. Procurement and personnel criteria use the current scheme required by the customer or regulator at the date of engagement.

K.2.7.3 The controls adapted here are qualified leadership, documented methodology, quality review independent of delivery, practical remediation, retest support, protected information handling, complaints and escalation routes, and competence matched to the technology and activity actually in scope.

K.2.8 NCSC, CISA and OWASP

K.2.8.1 United Kingdom National Cyber Security Centre (NCSC) guidance supports outcome-led exercise design and proportionate penetration testing. Its 2026 security-operations metrics guidance is reflected in Annex F: ticket, alert, rule and log-volume counts are means data and can create harmful incentives. The outward question is whether material activity was detected, examined, contained and recovered from in time.

K.2.8.2 United States Cybersecurity and Infrastructure Security Agency (CISA) red team assessments reinforce strict need-to-know controls, separation from defensive operations, deconfliction, protection of collected data and translation of observations into mitigations.

K.2.8.3 The Open Worldwide Application Security Project (OWASP) Web Security Testing Guide is the technical baseline when web or application testing is authorised. It informs test cases; it does not enlarge scope or convert a red team engagement into an exhaustive application assessment.

K.2.9 Privacy, evidence and service-provider conditions

K.2.9.1 GDPR and European Data Protection Board (EDPB) principles inform minimisation, purpose limitation, storage limitation, security and accountability where personal data is processed. Controller and processor roles, lawful basis, notices or lawful restrictions, international transfers, incident handling and any data-protection impact assessment are determined with the responsible privacy and legal functions.

K.2.9.2 ISO/IEC 27037 informs identification, collection, acquisition and preservation. The stricter evidential controls are activated where the intended use requires them.

K.2.9.3 AWS, Microsoft Azure and Google Cloud publish materially different testing policies. Permission may depend on the service, source infrastructure, technique and notice period. Current provider terms are therefore checked and evidenced per service before Gate G1 and again before Gate G3; no methodology text is treated as standing provider permission.

K.2.10 Exercise and practitioner sources

K.2.10.1 The Purple Team Exercise Framework v4 informs scheduled and operationalised collaboration at Annex H. Publications from the NATO Cooperative Cyber Defence Centre of Excellence (CCDCOE) inform complex cyber-exercise design where that model fits the organisation. Neither is automatically applicable to routine internal engagements.

K.2.10.2 Practitioner works support tradecraft and usability only after the proposed practice is checked against applicable authority, current official guidance and this methodology's safety controls.

K.3 Adoption decisions

Practice	Source	Position in this methodology	Qualification
Scope from critical functions	TIBER, CBEST	Default	Follow dependencies to systems, people, processes and third parties
Intelligence-led scenario selection	TIBER, DORA, CBEST	Required for red team engagements	Threat evidence, confidence, currency and limitations are recorded

Practice	Source	Position in this methodology	Qualification
Independent challenge of threat profile	TIBER, CBEST	Required	May be a qualified peer for a small internal team
Control Team separate from delivery and defence	TIBER, CBEST	Required for covert work	A Trusted Agent may be the whole Control Team on a tightly scoped engagement
Live-production testing	TIBER, DORA	Conditional	Only with explicit safety case, authority, provider permission and restoration controls
Golden-thread traceability	CBEST	Required	Threat to objective, action, evidence, observation, finding and remediation
Purple teaming at closure	TIBER 2025	Default	Mandatory when the applicable scheme requires it; omission otherwise needs rationale
Internal-test safeguards	DORA, TIBER	Scaled benchmark	Exact regulatory conditions apply only where legally applicable
Versioned ATT&CK mapping	MITRE	Required where ATT&CK is used	Coverage is not inferred from technique count alone
Attack Flow representation	Center for Threat-Informed Defense	Optional	Used when a branching path improves decision value
Measure specifications and quality limits	NIST SP 800-55, NCSC	Required	No target or trend without a defensible definition and comparison basis
Provider-policy and permission register	Provider policies	Required for hosted or managed services	Checked shortly before execution because terms change
Evidence identifiers, provenance and integrity	NIST, ISO/IEC 27037	Proportionate requirement	Formal chain of custody is claimed only when actually maintained
Formal regulator report or attestation	TIBER, DORA, CBEST	Scheme-specific	This methodology's internal cleanup attestation is not a regulatory attestation
Minimum active-test duration	TIBER	Scheme-specific	Not imported into ordinary internal work
External validation of the internal capability	DORA, CREST	Mandatory at the DORA cadence where applicable; planned at managed maturity otherwise	Also used whenever conflicts cannot be controlled internally
Retest and verified correction	CBEST, CREST, NIST	Required	Closure requires evidence, not task status
Full campaign emulation	MITRE resources	Advanced option	Used only where the decision and defensive maturity justify cost and exposure

K.4 Commissioning questions

K.4.1 An engagement is not approved until the accountable parties can answer these questions in writing.

#	Question	Control concern
1	What decision will the result inform?	Value and objective
2	Which critical function or material risk is being assessed?	Business relevance
3	What may go wrong, and who owns each consequence?	Operational risk
4	Could activity interrupt a critical service or impair recovery?	Safety and resilience
5	Whose system, third-party and provider permission is required?	Authority
6	What personal, confidential or classified data may be encountered?	Data risk
7	What happens if a genuine intrusion or reportable event is discovered?	Incident and notification duty
8	Who may know, stop, change, verify and receive the report?	Decision rights and secrecy
9	How will a claim be traced to trustworthy evidence?	Assurance
10	What constitutes detection, containment, recovery and successful improvement?	Measurement validity
11	How will every modification, credential, channel and infrastructure asset be removed?	Restoration
12	How will correction be funded, read across and retested?	Durable risk reduction

K.4.2 A capability able to answer these questions can be considered for approval. A team that cannot answer them should reduce the service line, move to a laboratory or open purple exercise, obtain external support, or defer the activity.

K.4.3 The corresponding customer questions begin on pro forma T01. The engagement-specific answers are then carried into T02, T03 and T04.

K.5 Concentration of effort

K.5.1 Areas of highest return

K.5.1.1 Early capacity is concentrated where it can produce verified defensive change. The order is adjusted to the organisation's risk profile.

Priority area	Why it matters	Practical first action
Identity, privilege and authentication	Most material paths cross identity controls	Establish what a compromised ordinary account can reach and how privilege is governed
Detection, examination and containment	Prevention alone does not show whether a surviving action is handled	Replay a short threat-relevant chain and reconcile each control stage
Remediation and retest	An unverified recommendation is not risk reduction	Retest critical and high findings and record exceptions transparently
Endpoint and identity telemetry quality	Rules cannot compensate for absent or unusable source data	Prove whether required events exist, are timely and carry stable identifiers
Recovery and backup administration	Adversary access to recovery systems changes mission consequence	Assess one authorised path from administration to recovery infrastructure

Priority area	Why it matters	Practical first action
Cloud and hosted control planes	Material actions may bypass network controls	Validate one identity or control-plane action against provider and defensive records
Email and collaboration	Initial access and rapid human reporting remain material	Measure delivery, reporting and time to first report without identifying individuals
Segmentation as implemented	Documented boundaries frequently differ from effective controls	Prove or disprove one material boundary and its monitoring
Third-party and machine access	Persistent trust paths are often weakly inventoried	Map supplier and workload identities; test only with direct permission
Decision and escalation practice	A technically correct alert can still fail operationally	Exercise one high-consequence escalation through containment and recovery

K.5.2 Effort deferred at startup

Deferred activity	Reason	Substitute
Custom command-and-control development	High maintenance and assurance cost	Approved established capability, isolated and tested
Broad covert campaigns	Exposure exceeds early programme learning capacity	Open or assumed-breach micro-emulation
Unknown-vulnerability research	Rarely the first control question	Emulate evidenced behaviours and known attack paths
Most advanced actor by default	Can produce predictable failure without useful discrimination	Test one capability step above demonstrated defence
Physical entry before governance is proven	High legal and personal-safety consequence	Tabletop, open exercise or specialist external support
Evasion for its own sake	Obscures whether base telemetry and process work	Add evasion only when the threat profile and objective require it
Exhaustive enumeration	Measures breadth of testing, not mission consequence	Follow a bounded path to a business objective

K.6 Controlled source register

K.6.1 Source-control rules

K.6.1.1 The register below identifies the authoritative public baseline. The Head of Red Team owns operational-source review; the legal adviser owns the determination of applicable law and regulation. Locally retained copies record source URL, title, edition, publication date, retrieval date and cryptographic hash.

K.6.1.2 Review occurs at least every six months, before a regulated engagement, and when an authority, provider or standards body announces a relevant change. Provider testing terms are additionally rechecked within the period set at Annex G, paragraph G.2.5.

K.6.1.3 A changed source does not silently alter an authorised engagement. The effect is assessed, the source register and affected controls are amended, and active Rules of Engagement are changed through their written change procedure.

K.6.2 Authoritative and official sources

Source and current baseline at issue	Used for	Review trigger
ECB TIBER-EU Framework 2025 and TIBER-EU portal	Threat-led lifecycle, Control Team, purple teaming, remediation	ECB framework or guidance update
TIBER Control Team Guidance 2025, Red Team Test Plan Guidance 2025, Blue Team Test Report Guidance 2025, and Attestation Guidance 2025	Role, plan, closure and scheme deliverables	ECB supporting-guidance update
Regulation (EU) 2022/2554, DORA and Delegated Regulation (EU) 2025/1190	Financial-sector applicability and internal tester safeguards	EUR-Lex amendment, corrigendum or new technical standard
Bank of England CBEST Implementation Guide 2024	Golden thread, operational risk, detection and response, read-across	Bank of England guide update
G7 Fundamental Elements for Threat-Led Penetration Testing	Proportional TLPT design, provider assurance, closure and thematic learning	G7 Cyber Expert Group update
NIST SP 800-115	Assessment lifecycle and planning	Revision or withdrawal
NIST SP 800-55 Volume 1 and Volume 2	Measure programmes, specifications, data quality and analysis	Revision or errata
NIST SP 800-61 Revision 3, SP 800-53 Revision 5, and SP 800-86	Incident integration, assessment controls and evidence handling	Revision or withdrawal
MITRE ATT&CK updates and adversary emulation plans	Versioned behaviour mapping and emulation inputs	ATT&CK release
Attack Flow 4.0	Branching attack-path model and stable flow identifiers	Specification release
NCSC SOC metrics guidance, penetration-testing guidance, and exercise guidance	Outcome measures, proportionate testing and exercise design	NCSC update
CREST 2026 CTI, TISA and TLPT scheme notice, financial-services TLPT guidance, and CREST Certified Red Team Manager syllabus v2.1	Provider assurance, competence and red team management	Scheme or syllabus change
CISA Red Team Assessment advisory	Need-to-know controls, deconfliction and mitigation focus	CISA replacement guidance
OWASP Web Security Testing Guide	Authorised web and application test design	Stable guide release
ISO/IEC 27037:2012	Digital evidence identification, collection, acquisition and preservation	ISO revision or systematic-review outcome
GDPR consolidated text and European Data Protection Board basic principles	Personal-data governance and accountability	Legislative, Court of Justice of the European Union or EDPB material change
AWS penetration-testing policy, Microsoft Cloud penetration-testing rules, and Google Cloud testing guidance	Provider-specific permission and prohibitions	Before each affected engagement

K.6.3 Non-normative supporting sources

Source	Permitted use
Vest and Tubberville, <i>Red Team Development and Operations</i>	Operator-record usability, engagement structure and tradecraft prompts
Zenko, <i>Red Team: How to Succeed by Thinking Like the Enemy</i>	Organisational independence and institutional failure modes
Purple Team Exercise Framework v4	Collaborative exercise design
Penetration Testing Execution Standard	Technical phase prompts where consistent with the ROE
NATO Cooperative Cyber Defence Centre of Excellence, <i>Crossed Swords: A Cyber Red Team Oriented Technical Exercise</i>	Complex exercise design

K.6.3.1 Practitioner sources may improve a procedure but cannot establish authority, regulatory compliance or provider permission. Technical claims are checked against current official documentation before use.

K.6.3.2 Third-party collections of books or PDFs, including public “hacking books” repositories, are discovery aids only. They are not ingested, redistributed or cited as controlled sources unless copyright or licence, provenance, completeness, edition and integrity have been established. A title found in such a collection is obtained from its publisher, author, library or another authorised source before it informs this methodology.

K.6.4 Derivation map

Control subject	Principal source basis	Implemented at
Authority, scope and provider permission	Applicable law; TIBER; DORA; provider policies	Chapters 5 and 8; Annexes B and G; T02 and T10
Role separation and small-team safeguards	TIBER; DORA; CBEST	Chapter 6; Annex A
Service selection, proportionality and commissioning	TIBER; G7; NCSC; CISA	Chapters 2 and 4; Annex H; T01
Lifecycle and gates	TIBER; CBEST; NIST SP 800-115	Chapter 7; Annex C
Threat-led planning and golden thread	TIBER; CBEST; MITRE	Annex D; T03 and T04
Behaviour and attack-path representation	MITRE ATT&CK; Attack Flow; TIBER	Annexes D and E; T03, T04 and T08
Execution records and evidence integrity	NIST SP 800-115; SP 800-86; ISO/IEC 27037	Annex E; T05 and T08
Deconfliction and genuine-intrusion handling	TIBER; CISA; NIST SP 800-61	Chapters 7 and 8; Annexes E and G; T02 and T07
Detection, response and measure quality	NIST SP 800-55; NCSC; TIBER	Chapter 9; Annex F; T08
Incident, privacy and data safeguards	NIST SP 800-61; GDPR/EDPB	Annexes E and G
Tooling, laboratory, competence and training	TIBER; DORA; CREST; NIST	Chapter 10; Annexes A and J; T04 and T05
Exercise and purple-team practice	TIBER; NCSC; Purple Team Exercise Framework; NATO CCDCOE	Annex H; T04, T08 and T11
Specialised-environment and safety controls	Applicable law, mandate and classification policy; TIBER	Chapters 4 and 8; Annexes G and I; T02
Cleanup, restoration and retest	TIBER; CBEST; CREST	Annex C; Annex F; T11 and T12

K.6.4.1 This is a control-family provenance map, not a clause-by-clause compliance statement. Where a law, contract, provider term or formal testing scheme applies, the current applicability assessment, authority requirements and scheme deliverables are recorded separately with the engagement.